CASE STUDY

The Year 2019 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

For the people who defend networks, 2019 was the year ransomware crews stopped spraying and started hunting. A Norwegian industrial group ran its plants by hand. Twenty-three Texas local government entities, by the state's own testimony, were hit in one August wave. On New Year's Eve more than 1,500 Travelex stores were reportedly affected. Criminal crews learned to pick large victims, move by hand across a network, and from November threaten to publish what they stole. The same year, the VPN and remote-access appliances that organizations put at their edge became the most reliable way in, for criminals and states alike. The flaws published in 2019 in Pulse Secure, Fortinet and Citrix gear became the three most exploited vulnerabilities of 2020. This study puts the year's public record in date order and grades every claim by the source that supports it.

The record supports five plain statements. First, ransomware became a targeted business: CrowdStrike called big game hunting the most lucrative crime enterprise of 2019, and Coveware's average ransom payment roughly doubled between the third and fourth quarters (**Confirmed** [116] [60]). Second, edge devices were the year's front door: the UK NCSC warned on 2 October 2019 that advanced actors were exploiting Pulse Secure, Fortinet and Palo Alto VPN flaws, and a joint advisory later named the 2019 Citrix and Pulse flaws and the Fortinet flaw patched in May 2019 as the top three exploited CVEs of 2020 (**Confirmed** [76] [73]). Third, patching was not enough: credentials stolen before a patch were reused months later, and CISA said a patch does not remove an actor already on a Citrix device (**Confirmed** [75] [71]; the general lesson is **Inferred**). Fourth, state operations kept their pace and governments named names, but often months later: the 28 October 2019 attack on Georgia was publicly attributed to Russia's GRU only on 20 February 2020 (**Confirmed** [1] [2]). Fifth, the best-documented data exposures of the year were configuration and design failures, not exotic exploits: Capital One's cloud firewall, First American's document URLs, and databases left open on the internet (**Confirmed** [91] [98]).

What this means for a security program is practical. Treat an internet-facing VPN, gateway or remote-desktop service as a crown-jewel asset with its own patch clock measured in days. After patching an edge device that was exposed, reset the credentials that passed through it and look for persistence before calling it clean. Keep offline backups and rehearse running without IT: Norsk Hydro restored from backups and ran plants by hand, and FBI named backups the most important defense (**Confirmed** [35] [52]). And check whether a ransom payment would reach a sanctioned party: from 5 December 2019 the US Treasury had sanctioned the Evil Corp crime group and said its leader worked for Russia's FSB (**Confirmed** [5]).

> Evidence grade: government statements, court records, vendor research and the CISA and NVD records are **Confirmed** against a primary source opened on 3 November 2026. Press coverage is **Reported**. Public exploit code is **Demonstrated**. Readings across sources are **Inferred** and labelled.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2019, with follow-on attribution, charges and fines into 2022 where they settle a 2019 event
Year in one line	Targeted ransomware, edge-appliance exploitation, cloud and web misconfiguration, and state actors named months after the fact
Largest reported crime losses	FBI IC3 2019: over $3.5 billion in reported losses, with business email compromise the top loss type at $1,776,549,688 [59]
Ransomware economics	Average payment $84,116 in Q4 2019, up 104 percent from Q3; Sodinokibi and Ryuk the most common families [60]
Most consequential 2019 flaws	CVE-2019-19781 (Citrix), CVE-2019-11510 (Pulse Secure) and CVE-2018-13379 (Fortinet, patched May 2019): the top three exploited CVEs of 2020 [73]; CVE-2019-0708 BlueKeep [61]
Government actions in 2019	Treasury sanctions on Lazarus Group, Bluenoroff and Andariel (13 Sep) and Evil Corp (5 Dec); CISA Emergency Directive 19-01 on DNS tampering (22 Jan); NCSC and NSA advisories on VPN flaws and Turla [29] [5] [118] [76] [7]
State activity named in 2019 records	Russia (Sandworm, APT28, APT29, Turla), China (APT41, APT10, GALLIUM, the Operation Wocao actor), Iran (APT33, Magic Hound, OilRig), North Korea (Lazarus Group, APT38, Andariel), Sea Turtle (no state named by Talos)
ATT&CK in force	v4, v5 and, from 24 October 2019, v6 (the cloud release); sub-techniques did not exist until v7 in July 2020 [112] [113] [114]
Book on the library list	*Sandworm* by Andy Greenberg, first published in hardcover on 5 November 2019 [6]
Home studies linked	APT41: The Public Record (APT41 and MESSAGETAP); SolarWinds (the Orion compromise, which began in September 2019)

Key findings

- **Big game hunting defined the crime year.** CrowdStrike tied Ryuk to WIZARD SPIDER with 705.80 BTC in tracked payments by January 2019; by year end WIZARD SPIDER alone accounted for a quarter of the eCrime CrowdStrike reported, and the largest listed demand was $12.5 million (**Confirmed** [32] [116]).

- **Extortion by leak went public in November 2019.** Maze published about 700 MB of Allied Universal files after a missed deadline, and by 19 December listed 11 victims publicly (**Reported** [53]; **Confirmed** for the December list [54]).
- **The edge was the front door.** Pulse Secure patched CVE-2019-11510 on 24 April 2019; over 14,500 servers were still unpatched on 24 August; the flaw was still a top-two exploited CVE in 2020 (**Confirmed** [58] [73]).
- **Patching did not end the incident.** In the Pulse cases CISA studied, victims that patched without resetting credentials stayed exposed, and CISA said a Citrix patch does not remediate a device already compromised (**Confirmed** [75] [71]).
- **BlueKeep was feared as a worm and used as a miner.** Microsoft called CVE-2019-0708 wormable on 14 May; the first in-the-wild campaign, with honeypot crashes from 23 October, delivered a coin miner and was operator-driven, not a worm (**Confirmed** [61] [64]).
- **State actors borrowed each other's tools.** NCSC and NSA said Turla used implants very likely Iranian in origin and accessed Iranian command panels, and Symantec documented a likely hostile takeover of OilRig infrastructure on a Middle Eastern target (**Confirmed** [7] [9]).
- **A firewall misconfiguration exposed about 106 million Capital One customers.** An outsider reached Capital One data on 22 and 23 March 2019 through a firewall misconfiguration in its cloud environment; about 106 million people in the US and Canada were affected, and the bank said the flaw was not specific to the cloud (**Confirmed** [89] [91]).
- **Attribution lagged events.** Georgia (October 2019) was attributed in February 2020; the Texas wave (August 2019) was tied to a named REvil affiliate only in 2021 (**Confirmed** [1]; **Reported** [47]).

Top recommendations

1. **Give edge devices a days-scale patch clock.** VPN concentrators, application delivery gateways and RDP hosts carried the year's most exploited flaws. Track them in an inventory with an owner and a deadline (Part 4).
2. **Reset credentials after an exposed edge device is patched.** Then check configuration, SSH authorized keys and firewall rules for changes, the sequence NCSC published in October 2019 (Part 4, Part 7).
3. **Rebuild, do not just patch, a compromised appliance.** CISA's Citrix detection guidance is explicit that patching does not evict an established actor (Part 4).
4. **Treat commodity malware as a ransomware precursor.** Emotet and TrickBot infections preceded Ryuk deployments; an Emotet alert deserves an incident response, not a cleanup ticket (Part 3).
5. **Keep offline backups and a manual-operations plan.** Norsk Hydro restored from backups and ran plants by hand; FBI named backups the most important defense (Part 3).
6. **Lock down cloud metadata and storage permissions.** Require IMDSv2, scope instance roles to the minimum, and alert on bulk storage listing and sync from unusual networks (Part 5).
7. **Protect DNS and registrar accounts with multi-factor authentication and watch Certificate Transparency logs** for certificates you did not request, as CISA's Emergency Directive 19-01 required (Part 2, Part 7).
8. **Screen ransom decisions against sanctions lists.** The Evil Corp designation made the payee a legal question (Part 6).

Scope and method

This study covers intrusions, exposures, vulnerability disclosures and government actions dated in 2019. An event that began in 2019 but was attributed, charged or fined later is recorded here with its later milestones; an event attributed in 2019 that happened earlier is recorded at its 2019 publication date. Two neighbouring studies are the home for their topics, and this study summarizes them in one paragraph each: APT41: The Public Record for APT41, its 2019 FireEye report and MESSAGETAP, and the SolarWinds study for the Orion compromise. The Georgia attack is recorded here as an event; its public attribution in February 2020 belongs to the 2020 chronicle, and this study only notes it (**Inferred** split, from the four-month gap between 28 October 2019 and 20 February 2020 [1]).

Every source was opened on 3 November 2026. Where a primary could not be opened, the study says so and cites the secondary that reports it at the **Reported** grade, or the government relay that states it. Numbers are given as each source states them; where two primaries disagree (Operation reWired arrests, the Texas victim count), both figures are shown. No quotation runs past 15 words.

Grade	Meaning in this study
Confirmed	The publisher of the fact was opened: a victim's own statement, a government advisory, sanction or court record, a vendor's research, NVD, KEV or the live ATT&CK page
Reported	Only a secondary source (press, a mirror, a book) was opened, or the primary states the claim only as media reporting
Demonstrated	Public exploit code or a public proof of concept exists; it does not by itself show in-the-wild use
Inferred	This study's own reasoning across sources, labelled where it appears

ATT&CK versions in 2019. During the year ATT&CK ran v4 (30 April to 30 July), v5 (31 July to 23 October) and v6 (from 24 October). v6 was the cloud release, adding or updating 36 techniques for AWS, Azure and GCP infrastructure and a SaaS platform (**Confirmed** [112] [113]). Sub-techniques arrived only in v7 on 8 July 2020, when 266 techniques became 156 techniques and 272 sub-techniques, so every 2019 vendor summary uses ids that have since changed (**Confirmed** [114]). This study gives every technique under its ATT&CK v20.0 id, mapping old ids through the library's `data/attack/superseded_by.jsonl`: for example T1086 PowerShell to `T1059.001`, T1060 to `T1547.001`, T1089 Disabling Security Tools to `T1685`, T1035 Service Execution to `T1569.002`, T1076 RDP to `T1021.001` and T1193 to `T1566.001`. T1064 Scripting is deprecated with no successor and is left out (**Confirmed** [115]).

Books. A book is a secondary source here. Andy Greenberg's *Sandworm*, on the library's book list, was first published in hardcover on 5 November 2019, a week after the Georgia attack (**Reported** [6]). Whether the book or a later afterword covers the Georgia attack was not checked, so no claim in this study rests on it.

Part 1: the year in date order

One row per event or report. "Grade" applies to the claim in the row. The Part column says where the study discusses it.

Date	Event	Actor (ATT&CK id where one exists)	Grade	Sources	Part
2019-01-10	CrowdStrike publishes "Big Game Hunting with Ryuk": Ryuk first seen mid-August 2018, 705.80 BTC across 52 transactions	WIZARD SPIDER (G0102)	Confirmed	[32]	3
2019-01-22	CISA Emergency Directive 19-01: federal agencies must audit DNS records, change DNS account passwords, add MFA and watch Certificate Transparency logs within 10 business days	Not named	Confirmed	[118]	2
2019-01-29	Kaspersky finds the backdoored ASUS Live Update tool; notifies ASUS on 2019-01-31	Not named at discovery	Confirmed	[11]	5
2019-02-06	Recorded Future and Rapid7 report APT10 intrusions at Visma, an apparel company and a US law firm (November 2017 to September 2018)	menuPass (G0045)	Reported	[13]	2
2019-02	Elfin uses WinRAR flaw CVE-2018-20250 against a Saudi chemical-sector target	APT33 (G0064)	Confirmed	[19]	2
2019-02	PINCHY SPIDER pushes affiliates toward big game hunting; later moves from GandCrab to REvil	GOLD SOUTHFIELD (G0115)	Confirmed	[116]	3
2019-02-18	Australian Prime Minister tells Parliament of a hostile intrusion into the Parliament House network and party networks	A sophisticated state actor, unnamed	Confirmed	[17]	2
2019-03-19	Norsk Hydro hit in the early hours; plants switch to manual operations; total cost later put at around 800 MNOK	LockerGoga (S0372) per Norway's NSM	Confirmed (attack, cost); Reported (malware)	[33] [34] [35] [36]	3
2019-03-20	Atlassian advisory for Confluence CVE-2019-3396 and CVE-2019-3395	n/a	Confirmed	[84]	4
2019-03-21	Facebook discloses that some passwords were stored readably in internal systems	n/a	Confirmed	[101]	5
2019-03-22 to 23	An outsider accesses Capital One data in its cloud environment	Individual, later convicted	Confirmed	[89] [91]	5
2019-03-25	Kaspersky discloses Operation ShadowHammer: over 600 targeted MAC addresses	Probably related to BARIUM per Kaspersky	Confirmed	[12]	5
2019-03-27	Symantec reports Elfin attacks on at least 50 organizations since 2016	APT33 (G0064)	Confirmed	[19]	2

Date	Event	Actor (ATT&CK id where one exists)	Grade	Sources	Part
2019-03-27	Microsoft announces, as court documents are unsealed, that a court order let its Digital Crimes Unit take control of 99 Phosphorus websites the week before	Magic Hound (G0059)	Confirmed	[20]	2
2019-04	Microsoft finds STRONTIUM using a VoIP phone, a printer and a video decoder to reach corporate networks (published 2019-08-05)	APT28 (G0007)	Confirmed	[3]	2
2019-04	Confluence CVE-2019-3396 exploited in the wild from April (AESDDoS botnet), later a miner with a rootkit	Criminal, unnamed	Confirmed	[85]	4
2019-04-03	A third-party Facebook app dataset of over 540 million records on public S3 is secured after press contact	Exposure, no actor	Confirmed	[102]	5
2019-04-10	DHS and FBI publish the HOPLIGHT malware analysis	HIDDEN COBRA, Lazarus Group (G0032)	Confirmed	[26]	2
2019-04-10	FireEye confirms the TRITON actor at an additional critical infrastructure facility	TEMP.Veles (G0088)	Confirmed	[30]	2
2019-04-17	Cisco Talos publishes Sea Turtle: DNS hijacking of at least 40 organizations in 13 countries	Sea Turtle (G1041)	Confirmed	[25]	2
2019-04-17	Sodinokibi delivered by exploiting Oracle WebLogic CVE-2019-2725, from at least this date	REvil (S0496) operators	Confirmed	[38]	3
2019-04-23	Kaspersky publishes ShadowHammer technical detail: two ASUS certificates, ShadowPad on a victim network	ShadowPad (S0596)	Confirmed	[11]	5
2019-04-24	Pulse Secure publishes fixes for CVE-2019-11510 and related flaws	n/a	Confirmed	[58]	4
2019-04-26	Oracle ships an out-of-band patch for CVE-2019-2725	n/a	Confirmed	[38]	3
2019-05	Maze ransomware discovered (previously ChaCha)	Maze (S0449)	Confirmed	[40]	3
2019-05-09	DHS and FBI publish the ELECTRICFISH tunneling tool analysis	HIDDEN COBRA	Confirmed	[27]	2
2019-05-14	Microsoft patches BlueKeep, CVE-2019-0708, including out-of-support XP and Server 2003	n/a	Confirmed	[61]	4
2019-05-24	Fortinet advisories for the FortiOS SSL VPN flaws, including CVE-2018-13379	n/a	Confirmed	[77] [78]	4

Date	Event	Actor (ATT&CK id where one exists)	Grade	Sources	Part
2019-05-24	About 885 million First American title documents reported reachable by changing digits in a URL	Exposure, no actor	Reported (count); Confirmed (defect, per SEC)	[97] [98]	5
2019-06-05	Qualys and Exim disclose CVE-2019-10149, moved up after a leak	n/a	Confirmed	[80] [81]	4
2019-06	Emotet goes quiet from the start of June; the latest Operation Ghost sample is dated June 2019	Emotet (S0367); APT29 (G0016)	Confirmed	[41] [4]	3, 2
2019-06-17	CISA AA19-168A on BlueKeep adds Windows 2000 and Vista to the affected list	n/a	Confirmed	[62]	4
2019-06-20	Symantec publishes Waterbug: 13 organizations in 10 countries since early 2018	Turla (G0010)	Confirmed	[9]	2
2019-06-22	CISA Director warns of rising Iranian destructive wiper activity	Iranian regime actors and proxies	Confirmed	[18]	2
2019-06-22	UK NCSC advisory on Ryuk targeting organizations globally (relayed by CISA on 2019-06-28)	Ryuk (S0446)	Confirmed	[42] [43]	3
2019-06-25	Cybereason's Operation Soft Cell against telecom providers, as reported by the press	GALLIUM (G0093) per ATT&CK	Reported	[14]	2
2019-07-15	Bulgaria's National Revenue Agency breached; data of over 5 million citizens	Not named	Reported	[111]	5
2019-07-24	FTC imposes a $5 billion penalty on Facebook	n/a	Confirmed	[103]	5
2019-07-29	Capital One announces the incident; DOJ announces an arrest	Individual	Confirmed	[89] [90]	5
2019-07-30	CISA ICSA-19-211-01, URGENT/11: eleven CVEs in the VxWorks IPnet stack	n/a	Confirmed	[86]	4
2019-07-31	Full Pulse Secure remote code execution exploit demonstrated	n/a	Confirmed (CERT/CC states it)	[74]	4
2019-08	Sandworm exploits Exim CVE-2019-10149 from at least this month (NSA, relayed by CISA)	Sandworm Team (G0034)	Confirmed	[82]	4
2019-08-05	Microsoft publishes the STRONTIUM corporate IoT findings	APT28 (G0007)	Confirmed	[3]	2
2019-08-07	FireEye publishes the APT41 report	APT41 (G0096)	Confirmed	[10]	2
2019-08-09	DEVCORE publishes its Fortinet SSL VPN research after Black Hat USA and DEF CON talks	n/a	Confirmed	[77]	4

Date	Event	Actor (ATT&CK id where one exists)	Grade	Sources	Part
2019-08-13	Microsoft patches the wormable RDS flaws CVE-2019-1181 and CVE-2019-1182	n/a	Confirmed	[65]	4
2019-08-14	Toyota Boshoku's European subsidiary loses up to about 4 billion yen to fraudulent payment directions	A malicious third party	Confirmed	[45]	3
2019-08-16	Coordinated ransomware attack on Texas local government entities (23 per DIR testimony)	REvil affiliate, named in 2021	Confirmed (attack); Reported (actor)	[46] [47]	3
2019-08-21 to 31	Public Pulse exploit code and forum discussion appear; over 14,500 unpatched Pulse servers found on 2019-08-24	n/a	Confirmed (14,500 scan and late-August PoC, as CISA states); Reported (21 August exploit date [56])	[58] [75] [56]	4
2019-08 to 09	Phosphorus makes more than 2,700 attempts to identify accounts over 30 days, compromising 4	Magic Hound (G0059)	Confirmed	[21]	2
2019-08-28	Capital One defendant indicted: data from more than 30 other entities, cryptocurrency mining on victims' servers	Individual	Confirmed	[92]	5
2019-08-30	UN Panel of Experts report on at least 35 reported DPRK attacks in 17 member states	DPRK actors	Confirmed	[28]	2
2019-09	Earliest suspicious activity in the SolarWinds environment; October Orion release carries test modifications	APT29 (G0016) per ATT&CK campaign C0024	Confirmed	[123] [124]	5
2019-09-04	Server with over 419 million Facebook phone-number records reported	Scraped data, no actor	Reported	[104]	5
2019-09-06	Rapid7 releases the first public Metasploit BlueKeep module	n/a	Demonstrated	[63]	4
2019-09-10	FBI PSA on $26.2 billion in exposed BEC losses; Operation reWired announced (281 arrests)	BEC networks	Confirmed	[49] [50] [51]	3
2019-09-13	Treasury designates Lazarus Group, Bluenoroff and Andariel	G0032, G0082, G0138	Confirmed	[29]	2, 6
2019-09-16	Emotet fully reawakened and spamming, with email thread hijacking	Emotet (S0367)	Confirmed	[41]	3
2019-09-16	vpnMentor reports an open server holding data on over 20 million people in Ecuador (closed 2019-09-11)	Exposure, Novaestrat apparent owner	Confirmed	[108]	5
2019-10-01	Armis extends URGENT/11 to six more real-time operating systems	n/a	Confirmed	[87]	4

Date	Event	Actor (ATT&CK id where one exists)	Grade	Sources	Part
2019-10-02	NCSC alert on APT exploitation of Pulse Secure, Fortinet and Palo Alto VPNs; FBI PSA on high-impact ransomware	APT actors, unnamed	Confirmed	[76] [52]	4, 3
2019-10-04	Microsoft discloses Phosphorus targeting of a US presidential campaign	Magic Hound (G0059)	Confirmed	[21]	2
2019-10-07	NSA advisory on APT targeting of VPNs (known through the CISA and CERT/CC relays)	APT actors	Confirmed (relay)	[58] [74]	4
2019-10-17	ESET publishes Operation Ghost against foreign ministries in at least three European countries	APT29 (G0016); campaign C0023	Confirmed	[4]	2
2019-10-21	NCSC and NSA advisory: Turla used Iranian-origin tools and accessed Iranian command panels	Turla (G0010)	Confirmed	[7] [8]	2
2019-10-23	BlueKeep honeypot crashes begin; Kevin Beaumont's honeypot crashes on 2019-11-02; payload is a coin miner	Operator, unnamed	Confirmed	[64]	4
2019-10-24	ATT&CK v6, the cloud release	n/a	Confirmed	[113]	Scope
2019-10-28	Disruptive attack on Georgia: several thousand websites disrupted and many defaced, at least two TV stations interrupted	Sandworm Team (G0034), GRU GTsST, attributed 2020-02-20	Confirmed	[1] [2] [119]	2
2019-11-05	Andy Greenberg's *Sandworm* published	n/a	Reported	[6]	Scope
2019-11-19	AWS releases IMDSv2	n/a	Confirmed	[96]	5
2019-11-21	Maze publishes about 700 MB of Allied Universal files after a missed deadline	Maze (S0449) operators	Reported	[53]	3
2019-12-05	Treasury sanctions Evil Corp and Maksim Yakubets; FBI charges Yakubets and Igor Turashev	Indrik Spider (G0119)	Confirmed	[5] [55]	3, 6
2019-12-05	IBM X-Force ZeroCleare wiper reported	ZeroCleare (S1151); OilRig (G0049) per ATT&CK	Reported (IBM); Confirmed (ATT&CK)	[22] [23]	2
2019-12-12	Microsoft publishes GALLIUM telecom targeting	GALLIUM (G0093)	Confirmed	[15]	2
2019-12-17	Citrix discloses CVE-2019-19781 with interim mitigations	n/a	Confirmed	[68]	4
2019-12-19	Fox-IT publishes Operation Wocao; SentinelLabs reports Maze's public list of 11 victims	Wocao actor, campaign C0014; Maze	Confirmed	[16] [54]	2, 3

Date	Event	Actor (ATT&CK id where one exists)	Grade	Sources	Part
2019-12-29	Dustman wiper hits Bapco in Bahrain (made public in January 2020)	No actor named	Reported	[24]	2
2019-12-31	Travelex hit by Sodinokibi; more than 1,500 stores affected	REvil (S0496) operators	Reported	[56]	3

ATT&CK's own campaign records also place several campaigns in 2019 by first and last seen dates: Frankenstein (C0001, January to April 2019), Operation Sharpshooter (C0013, to March 2019), Operation Wocao (C0014, to December 2019), Operation Dream Job (C0022, from September 2019), Operation Ghost (C0023, to October 2019) and the SolarWinds Compromise (C0024, from August 2019) (**Confirmed** [40]). This study covers those with an opened primary; the others are listed for completeness.

Part 2: state operations

Russia

Georgia, 28 October 2019. Attacks on Georgian web hosting providers defaced government, court, NGO, media and business websites and interrupted several national broadcasters (**Confirmed** [1]). The US State Department put the damage at several thousand government and private websites and at least two major television stations (**Confirmed** [2]). ATT&CK's Sandworm Team page records about 15,000 websites defaced, service disruption after the compromise of a web hosting provider, and reconnaissance of the Parliament of Georgia's domain before the attack (**Confirmed** [119]). On 20 February 2020 the UK attributed the attacks to the GRU's Main Centre of Special Technologies (GTsST, field post 74455), known as Sandworm, BlackEnergy Group, Telebots and VoodooBear, with NCSC confidence of almost certainly; the US State Department named the same unit the same day (**Confirmed** [1] [2]). The attribution is a 2020 event and is told in the 2020 chronicle.

Sandworm and Exim. NSA said Sandworm had exploited unpatched Exim mail servers through CVE-2019-10149 since at least August 2019, an advisory CISA relayed in May 2020; the NSA document itself could not be opened (**Confirmed** as relayed [82]). Part 4 covers the flaw.

APT28 and office devices. In April 2019 Microsoft found STRONTIUM (APT28, G0007) using a VoIP phone, an office printer and a video decoder to get into corporate networks. Two devices still had default passwords and the third lacked the latest update. Once in, the actor ran tcpdump, enumerated administrative groups and dropped a shell script for persistence. Microsoft said it had sent nearly 1,400 STRONTIUM notifications in the prior twelve months (**Confirmed** [3]).

APT29 and Operation Ghost. ESET reported on 17 October 2019 that the Dukes (APT29, G0016) had run a campaign since 2013 against foreign ministries in at least three European countries and the Washington embassy of an EU member state, with the latest sample from June 2019. The campaign used new families PolyglotDuke, RegDuke and FatDuke plus an updated MiniDuke. PolyglotDuke fetched its command server addresses from posts on Twitter, Reddit and Imgur and used image steganography; RegDuke used Dropbox for command and control (**Confirmed** [4]). ATT&CK records the campaign as Operation Ghost, C0023 (**Confirmed** [40]). APT29's other 2019 thread, the first activity in the SolarWinds build environment, is summarized in Part 5.

Turla borrows Iran's tools. Symantec reported on 20 June 2019 that Waterbug (Turla, G0010) had attacked 13 organizations in 10 countries since early 2018. On one Middle Eastern government target, Crambus (OilRig) had been present since November 2017; Waterbug arrived on 11 January 2018, and the next day a custom Mimikatz was downloaded from a Crambus command server through Crambus's own Powruner and Poison Frog tools, which Symantec read as a likely hostile takeover. Waterbug's new tools included a Neptun backdoor for Exchange servers, Base64 PowerShell stored in the registry, certutil downloads, a USB stealer and exfiltration to Box over WebDAV (**Confirmed** [9]). On 21 October 2019 NCSC and NSA went further: the Neuron and Nautilus implants Turla used were very likely Iranian in origin and their original operators almost certainly unaware; Turla scanned for an ASPX web shell on IP addresses in at least 35 countries, one log holding over 3,500 unique addresses; and it reached Poison Frog command panels attributed to APT34/OilRig and took directory listings, keylogger output, victim lists and credentials, with a focus on the Middle East (**Confirmed** [7] [8]). The NCSC news page does not itself name OilRig, so linking ATT&CK's OilRig (G0049) rests on the advisory's APT34/OilRig wording and Symantec's Crambus finding (**Inferred** link [8] [9]).

Crime in state service. Treasury's 5 December 2019 Evil Corp action said its leader Maksim Yakubets was working for the FSB as of 2017 and was tasked with state projects, and framed it as Russia enlisting cybercriminals (**Confirmed** [5]). Part 3 covers the group's crimes.

China

APT41. FireEye's 7 August 2019 report described a group running espionage and financially motivated operations at the same time from 2014, with activity since 2012: espionage against healthcare, high tech and telecoms, crime against video game companies, supply-chain code injection, stolen code-signing certificates, master boot record bootkits, over 46 malware families and tools, and follow-on malware that only runs on machines with chosen identifiers (**Confirmed** [10]). The full record, including the 2019 MESSAGETAP telecom tool (S0443) and the 2019 and 2020 indictments, lives in APT41: The Public Record. The ASUS ShadowHammer compromise, which Kaspersky called probably related to BARIUM (an alias ATT&CK lists for APT41), is in Part 5.

APT10 and the managed service provider route. Recorded Future and Rapid7 reported on 6 February 2019 that APT10 (menuPass, G0045) had intruded at Visma, an international apparel company and a US law firm between November 2017 and September 2018. The actor came in through Citrix with stolen credentials, loaded Trochilus by DLL side-loading, used UPPERCUT, and sent data to the Dropbox API with renamed copies of WinRAR and cURL; the report read the aim as a second hop into Visma's clients and framed it as an extension of the Cloud Hopper campaign charged in a December 2018 DOJ indictment. The original report no longer opens (404 at the publisher; archived captures refused with 429 on 4 November 2026), so this rests on a third-party copy of the report (**Reported** [13]).

Telecoms: Soft Cell and GALLIUM. Cybereason's Operation Soft Cell, as Security Affairs reported it on 25 June 2019, described long-running espionage against multiple telecom providers for call detail records, active since at least 2012, using a modified China Chopper web shell on IIS, NBTscan, Poison Ivy, Mimikatz, HTRAN, WMI, PsExec and WinRAR, with a likely APT10 link by tradecraft (**Reported** [14]). ATT&CK places Soft Cell under GALLIUM (G0093) (**Confirmed** [40]). Microsoft's own GALLIUM post of 12 December 2019 does not mention Soft Cell. It describes telecom targeting from 2018 to mid-2019 through unpatched internet-facing WildFly/JBoss services; China Chopper and BlackMould web shells; Mimikatz, Windows Credential Editor, HTRAN, PsExec, NBTscan, Netcat and WinRAR; a modified Poison Ivy, the Gh0st variant QuarkBandit and SoftEther VPN; and command servers on dynamic DNS subdomains (**Confirmed** [15]).

Operation Wocao. Fox-IT's 19 December 2019 report attributed a campaign to a Chinese actor with high confidence and to APT20 with medium confidence, with victims in more than 10 countries across government, managed service providers, energy, health care and high tech. The actor relied on legitimate access such as VPN and abused two-factor soft tokens (**Confirmed** [16]). ATT&CK records it as campaign C0014 (**Confirmed** [40]). The full PDF's specifics were not checked.

Australia's Parliament. On 18 February 2019 the Prime Minister told Parliament that the Australian Cyber Security Centre had found a hostile intrusion into the Parliament House network, that Liberal, Labor and National party networks were also affected, and that experts believed a sophisticated state actor was responsible. He said there was no evidence of electoral interference and named no state (**Confirmed** [17]).

Iran

The June warning. On 22 June 2019 CISA's Director warned of a rise in malicious activity by Iranian regime actors and proxies, increasingly using destructive wiper attacks enabled by spear phishing, password spraying and credential stuffing (**Confirmed** [18]).

Elfin. Symantec reported on 27 March 2019 that Elfin (APT33, G0064) had attacked at least 50 organizations since 2016, 42 percent of them in Saudi Arabia and 18 in the United States. In February 2019 it used WinRAR CVE-2018-20250 against a Saudi chemical-sector target. A Stonedrill victim overlapped the December 2018 Shamoon wave, but Symantec found no further evidence that Elfin ran Shamoon. Tools included Notestuk (TURNEDUP), Stonedrill, Remcos, DarkComet, Quasar, Pupy, NanoCore, LaZagne and Mimikatz (**Confirmed** [19]).

Phosphorus. On 27 March 2019 Microsoft announced, as court documents were unsealed, that an order from the US District Court in Washington D.C. had let its Digital Crimes Unit take control of 99 Phosphorus websites (APT35, Charming Kitten; ATT&CK Magic Hound, G0059) the week before. The group used spear phishing, fake security alerts leading to credential forms, and lookalike domains (**Confirmed** [20]). Over 30 days in August and September 2019 it made more than 2,700 attempts to identify accounts, attacked 241 and compromised 4, none of them campaign or government accounts; targets included a US presidential campaign, and the method abused password reset and account recovery with researched personal data and phone numbers (**Confirmed** [21]).

ZeroCleare and Dustman. IBM X-Force's December 2019 ZeroCleare report, known here through The Register because the IBM primary could not be reached, described a wiper that used the EldoS RawDisk driver seen in Shamoon, with reconnaissance from autumn 2018, a password spray in summer 2019, ASPX web shells and domain admin access, and X-Force's belief that it was partly APT34's work (**Reported** [22]). ATT&CK's ZeroCleare entry (S1151) lists OilRig (G0049) as collaborating on the destructive portion, plus VOID MANTICORE (G1055) (**Confirmed** [23]). On 29 December 2019 the Dustman wiper hit Bapco in Bahrain. Kaspersky ICS CERT summarizes the Saudi National Cybersecurity Authority report: an improved ZeroCleare variant using RawDisk and a modified Turla Driver Loader, likely entry through a VPN appliance remote-execution flaw, spread with the antivirus management console's service account and PsExec, only some machines infected, and no actor named (**Reported** [24]).

Sea Turtle and the DNS layer

Cisco Talos reported on 17 April 2019 a state-sponsored DNS hijacking campaign against at least 40 organizations in 13 countries, mainly in the Middle East and North Africa, from January 2017 to the first quarter of 2019. Initial access came through spear phishing or known CVEs: CVE-2009-1151, CVE-2014-6271, CVE-2017-3881, CVE-2017-6736, CVE-2017-12617, CVE-2018-0296 and CVE-2018-7600. Talos judged it distinct from DNSpionage and named no state (**Confirmed** [25]). The actor reached primary victims through DNS registrars, telecoms and ISPs, in what Talos called the first publicly confirmed case against an organization managing a root server zone (**Confirmed** [25]). ATT&CK records the group as Sea Turtle (`G1041`) (**Confirmed** [40]). Three months earlier CISA's Emergency Directive 19-01 had described the same class of attack, traffic redirected and intercepted with valid certificates, and ordered federal agencies to audit DNS records, change DNS account passwords, add multi-factor authentication and monitor Certificate Transparency logs within 10 business days; the directive is now closed (**Confirmed** [118]).

North Korea

HOPLIGHT and ELECTRICFISH. DHS and FBI's HOPLIGHT analysis (AR19-100A, 10 April 2019) covered nine executables, seven of them proxies that generate fake TLS handshakes with valid public certificates, attributed to HIDDEN COBRA (Lazarus Group, `G0032`); ATT&CK records HOPLIGHT as `S0376` (**Confirmed** [26]; ATT&CK object [40]). ELECTRICFISH (AR19-129A, 9 May 2019) tunnels traffic between two IP addresses with a custom protocol and can authenticate to a proxy (**Confirmed** [27]). ELECTRICFISH has no ATT&CK software object in the library data (**Confirmed** [40]).

Theft at scale. The UN Panel of Experts report of 30 August 2019 (S/2019/691, paragraphs 57 and 58) said it was investigating at least 35 reported DPRK attacks on financial institutions, cryptocurrency exchanges and mining in 17 member states, 10 of them in the Republic of Korea, with some estimates of proceeds as high as $2 billion. Methods were SWIFT attacks, cryptocurrency theft and mining; one ATM network compromise forced 10,000 cash distributions in more than 20 countries in five hours (**Confirmed** [28]). On 13 September 2019 Treasury designated Lazarus Group, Bluenoroff and Andariel as controlled by the Reconnaissance General Bureau under Executive Order 13722, citing industry and press reporting that the three groups likely stole about $571 million in cryptocurrency from five Asian exchanges between January 2017 and September 2018, and that Bluenoroff had attempted to steal over $1.1 billion (**Confirmed** that Treasury said so [29]). In ATT&CK these are Lazarus Group (`G0032`), APT38 (`G0082`, which carries the Bluenoroff alias in the library data) and Andariel (`G0138`) (**Confirmed** [40]).

The TRITON actor returns

FireEye reported on 10 April 2019 that it had found the TRITON actor at an additional critical infrastructure facility. The actor had been inside almost a year before reaching the safety instrumented system engineering workstation, and had been active since at least 2014. Its kit included Mimikatz, SecHack, NetExec, a cryptcat backdoor and PLINK; it modified Outlook Web Access files into web shells, renamed tools to look like Microsoft updates and a Schneider Electric application, timestomped files, tunneled over encrypted SSH and worked off-hours (**Confirmed** [30]). ATT&CK's campaign `C0030` covers the 2017 Triton attack (June to August 2017) by TEMP.Veles (`G0088`); the 2019 second-victim report is a separate event, and the library has no page for the Triton software object, so only the campaign and group are linked (**Confirmed** [31]).

Part 3: big game hunting and the crime economy

The Ryuk pipeline

CrowdStrike's 10 January 2019 report set out the model the year would follow. Ryuk, first seen in mid-August 2018 as a modified Hermes, was run by WIZARD SPIDER (G0102) and had drawn 705.80 BTC across 52 transactions, about $3.7 million at the time, with demands from 1.7 to 99 BTC. TrickBot (S0266) did the initial compromise, often delivered by Emotet (S0367); operators pushed Ryuk with PsExec, stopped services with a kill.bat script, deleted shadow copies with vssadmin, moved by RDP, used PowerShell Empire (S0363), and in earlier builds persisted through a Run key (**Confirmed** [32]). The UK NCSC issued a Ryuk advisory dated 22 June 2019; the NCSC page is now removed and the date comes from the Canadian Centre's relay (**Confirmed** [42]). CISA relayed it on 28 June with pointers to its Emotet alert TA18-201A and an MS-ISAC TrickBot primer (**Confirmed** [43]). FBI later reported TrickBot "Anchor" modules from early 2019, including anchor_dns, which tunnels command traffic over DNS with the single-byte XOR key 0xB9, and listed the Ryuk toolkit: kill scripts, vssadmin, RDP, WMI, Mimikatz, scheduled tasks, services and security-tool removal (**Confirmed** [44]).

Emotet itself went quiet from the start of June 2019 and was fully back and spamming by 16 September, hijacking existing email threads with stolen mail and sending infected Word attachments; Talos counted 202,675 stolen SMTP credential pairs over 10 months (**Confirmed** [41]). Microsoft later framed REvil, Samas, BitPaymer and Ryuk as human-operated ransomware that often begins from commodity malware triaged as unimportant (**Confirmed** [122]).

Norsk Hydro

Norsk Hydro was hit in the early hours of Tuesday 19 March 2019 (CET). IT in most business areas was affected and plants switched to manual operations; an update the same day confirmed manual running and ongoing response (**Confirmed** [33] [34]). Hydro later said Extruded Solutions was hardest hit and the total cost was around 800 MNOK, with recovery from backups and manual procedures (**Confirmed** [35]). Hydro's pages do not name the malware. Reuters reported that Norway's NSM said the attack used LockerGoga (S0372), that Hydro would not pay and would restore from backups, and that the company had 36,000 staff in 40 countries (**Reported** [36]). ATT&CK's LockerGoga page names European industrial firms but not Hydro (**Confirmed** [124]). On 26 October 2021 a Europol-coordinated action against 12 suspects tied to LockerGoga, MegaCortex (S0576) and Dharma, with about 1,800 victims in 71 countries, was linked to Hydro by Norwegian police; the Europol page did not render, so this rests on press coverage (**Reported** [37]). CrowdStrike said LockerGoga was only briefly active in 2019 (**Confirmed** [116]).

Sodinokibi, GandCrab and REvil

Talos reported in late April 2019 that Sodinokibi had been delivered since at least 17 April by exploiting Oracle WebLogic CVE-2019-2725, which Oracle patched out of band on 26 April (CVSS 9.8). The attackers used PowerShell and certutil to download it and deleted shadow copies with vssadmin; about eight hours later the same actors dropped GandCrab v5.2 (**Confirmed** [38]). NVD lists CVE-2019-2725 as CWE-74, and KEV added it on 10 January 2022 (**Confirmed** [39] [66]). CrowdStrike tracked PINCHY SPIDER's move from GandCrab to REvil (S0496) and its push toward big game hunting from February 2019 (**Confirmed** [116]); ATT&CK records the operators as GOLD SOUTHFIELD (G0115) (**Confirmed** [40]). GandCrab has no ATT&CK object in the library data (**Confirmed** [40]).

Texas. Texas DIR testimony says twenty-three local government entities were hit by a coordinated ransomware attack in August 2019; DIR press releases with a revised count of 22 could not be opened (**Confirmed** for 23 [46]). The Record later reported that the attack was attributed to REvil affiliate Yevgeniy Polyanin through the managed service provider TSM Consulting, affecting at least 20 agencies (**Reported** [47]). Treasury designated Polyanin and Yaroslav Vasinskyi for Sodinokibi/REvil on 8 November 2021 and said the group had received more than $200 million in ransom; the release does not mention Texas (**Confirmed** [48]).

Travelex. On 31 December 2019 Sodinokibi hit Travelex. BleepingComputer reported more than 1,500 stores affected, a $3 million demand and a claim of 5 GB stolen, and that Travelex ran Pulse Secure VPN servers vulnerable to CVE-2019-11510 (public exploit 21 August 2019, patch 24 April 2019); the entry vector was not officially confirmed in the reporting opened (**Reported** [56]). Travelex reportedly paid about $2.3 million, according to BleepingComputer citing the Wall Street Journal (**Reported** [57]). CISA's January 2020 advisory recorded media reports of REvil installs through unpatched Pulse servers and attributes that item to the media itself (**Confirmed** that CISA recorded it; the installs are **Reported** [58]).

Maze and the leak threat

Maze (`S0449`) was discovered in May 2019 and was previously known as ChaCha (**Confirmed** [40]). In November it published about 700 MB of Allied Universal files, which it said was 10 percent of what it took, after a missed deadline; the demand was 300 BTC (about $2.3 million) and then $3.8 million, and BleepingComputer called it the first known follow-through on a leak threat (**Reported** [53]). SentinelLabs' update of 19 December 2019 recorded that Maze had gone fully public with a list of 11 non-compliant victims, including Allied (written "Allied Financial", which does not match Allied Universal) and the City of Pensacola (**Confirmed** [54]).

Evil Corp

On 5 December 2019 Treasury sanctioned Evil Corp and its leader Maksim Yakubets: Dridex (`S0384`) had been used to steal more than $100 million, with credentials taken from about 300 banks in over 40 countries as of 2016; the State Department offered a reward of up to $5 million; and Yakubets was working for the FSB as of 2017 (**Confirmed** [5]). FBI announced charges against Yakubets and Igor Turashev, said later Bugat/Dridex versions installed ransomware, and called the reward the largest ever offered for a cyber criminal (**Confirmed** [55]). The library's ATT&CK data lists Evil Corp among the aliases of Indrik Spider (`G0119`), whose BitPaymer (`S0570`) was among CrowdStrike's 2019 big game hunting families (**Confirmed** [40] [116]). Treating Treasury's Evil Corp and ATT&CK's Indrik Spider as the same set of people is the alias table's reading, not Treasury's (**Inferred**).

Business email compromise

In the FBI's own counts business email compromise losses far exceeded reported ransomware losses, though IC3 calls its ransomware figure artificially low (**Inferred** from [49] [59]). FBI's PSA of 10 September 2019 reported $26,201,775,589 in exposed BEC losses across 166,349 incidents from June 2016 to July 2019, global exposed losses up 100 percent from May 2018 to July 2019, and payroll diversion losses up more than 815 percent from 1 January 2018 to 30 June 2019 (**Confirmed** [49]). The same day FBI announced Operation reWired: 281 arrests, 74 of them in the US, nearly $3.7 million seized and about $118 million in wires disrupted or recovered (**Confirmed** [50]). The DOJ Inspector General's audit of FBI's FY2019 statements gives 282 arrests and over $3.6 million seized, a one-arrest difference (**Confirmed** [51]). Toyota Boshoku disclosed that its European subsidiary lost up to about 4 billion yen to fraudulent payment directions from a malicious third party on 14 August 2019 (**Confirmed** [45]).

The numbers for the year

Measure	Value	Source
IC3 complaints, 2019	467,361 complaints; losses over $3.5 billion	[59]
BEC/EAC, 2019	23,775 complaints; $1,776,549,688 adjusted losses, the top loss type	[59]
Ransomware reported to IC3, 2019	2,047 complaints; $8,965,847, which IC3 calls artificially low because it excludes lost business and remediation	[59]
IC3 Recovery Asset Team, first full year	Over $300 million recovered, a 79 percent return rate	[59]
Average ransom payment, Q4 2019	$84,116, up 104 percent from $41,198 in Q3; median $41,179	[60]
Ransomware downtime, Q4 2019	16.2 days (12.1 in Q3)	[60]
Price of RDP access	As little as $30 per IP address	[60]
eCrime breakout time	4 h 37 min (2018) to 9 h (2019)	[116]
Ransomware share of malware incidents	27 percent (Verizon DBIR, 1 November 2018 to 31 October 2019)	[117]

All **Confirmed** against the publisher. FBI's 2 October 2019 PSA explains the shape: broad ransomware campaigns had declined since early 2018 while losses rose, attacks were more targeted, the ways in were phishing, RDP brute force or bought credentials, and software flaws including MSP remote management tools (at least three MSPs), FBI did not advocate paying, and backups were named the most important defense (**Confirmed** [52]).

Part 4: the vulnerabilities of 2019

Remote Desktop: BlueKeep and its successors

On 14 May 2019 Microsoft patched BlueKeep, CVE-2019-0708, and called it wormable: no authentication and no user interaction. It affected Windows 7, Server 2008 and 2008 R2, and out-of-support XP and Server 2003, for which Microsoft shipped fixes; Windows 8 and 10 were not affected, and no exploitation had been seen when the patch shipped. Network Level Authentication only partly mitigates it (**Confirmed** [61]). NVD scores it 9.8 and lists CWE-416 (**Confirmed** [39]). CISA's AA19-168A of 17 June added Windows 2000 and Vista to the affected list and advised enabling NLA and blocking TCP 3389 at the perimeter (**Confirmed** [62]). Rapid7 released the first public Metasploit module on 6 September, for 64-bit Windows 7 and Server 2008 R2; it needed manual targeting and could crash the target (**Demonstrated** [63]). Microsoft's telemetry showed RDP crashes rising after that release; honeypot crashes were seen from 23 October and Kevin Beaumont's honeypot crashed on 2 November; the payload was a coin miner and Microsoft judged the activity operator-driven, not a worm (**Confirmed** [64]). On 13 August Microsoft patched two more wormable RDS flaws, CVE-2019-1181 and CVE-2019-1182, affecting Windows 7 SP1 through Windows 10, with no evidence third parties knew of them; NVD scores both 9.8 and neither is in KEV (**Confirmed** [65] [39] [66]). KEV added BlueKeep on 3 November 2021 with ransomware use marked Known, and CISA later listed it among CVEs used by Chinese state-sponsored actors (**Confirmed** [66] [67]).

The VPN year: Pulse Secure, Fortinet and Palo Alto

Pulse Secure. Pulse published fixes for CVE-2019-11510 and related flaws on 24 April 2019 (**Confirmed** [58]). NVD scores CVE-2019-11510, an unauthenticated file read, at 10.0 with CWE-22, and CVE-2019-11539, a post-authentication admin command injection, at 7.2 with CWE-78 (**Confirmed** [39]). CERT/CC's VU#927237 covers ten Pulse CVEs and notes that session IDs can be read from the appliance, so client certificates and two-factor authentication do not stop a takeover; a full remote code execution exploit was demonstrated on 31 July 2019 (**Confirmed** [74]). Forum discussion and proof-of-concept code appeared in late August, and on 24 August Bad Packets found more than 14,500 unpatched Pulse servers, a scan known here through the CISA and CERT/CC relays because the Bad Packets original is offline (**Confirmed** as relayed [75] [58]). In the Pulse cases CISA studied, actors harvested plaintext Active Directory credentials and persisted through scheduled tasks, remote access tools, LogMeIn and TeamViewer, proxying through Tor and rented servers; one actor sold credentials and later ransomed hospitals; victims that patched without resetting credentials stayed exposed, with the last unauthorized connections seen on 15 February 2020 (**Confirmed** [75]).

Fortinet. DEVCORE researchers Meh Chang and Orange Tsai reported the FortiOS SSL VPN flaws to Fortinet on 11 December 2018; advisories followed on 24 May 2019, and the researchers presented at Black Hat USA and DEF CON 2019. Their write-up covers CVE-2018-13379 to CVE-2018-13383, including a "magic" parameter in CVE-2018-13382 that resets a user's password (**Confirmed** [77]). Fortinet's FG-IR-18-384 lists FortiOS 6.0.0 to 6.0.4, 5.6.3 to 5.6.7 and 5.4.6 to 5.4.12 as affected when SSL VPN is enabled, at vendor CVSS 9.1; a 30 August 2019 update added 2FA as a mitigation. NVD published CVE-2018-13379 on 4 June 2019 at 9.8 with CWE-22 (**Confirmed** [78]). In November 2020 Fortinet said IP addresses of unpatched devices were reportedly being sold and that it had sent tailored notices to more than 50,000 customers about the 18-month-old flaw (**Confirmed** [79]). Two companion FortiOS CVEs went into KEV on 3 November 2021: CVE-2020-12812, a 2FA bypass by changing the case of the username, and

CVE-2019-5591, LDAP impersonation from the same subnet in the default configuration (**Confirmed** [66]).

The warnings. On 2 October 2019 (version 2.0 on 8 October) the UK NCSC said APT actors were exploiting Pulse Secure, Fortinet and Palo Alto VPN flaws against government, military, academic, business and healthcare targets in the UK and abroad. Its essential steps were to patch and reset credentials, then check configuration, SSH authorized keys and iptables (**Confirmed** [76]). NSA issued its own VPN advisory on 7 October 2019, known here only through the CISA and CERT/CC relays because the NSA document could not be opened (**Confirmed** as relayed [74] [58]). The Palo Alto GlobalProtect flaw CVE-2019-1579 went into KEV on 10 January 2022 (**Confirmed** [66]).

Citrix, the December flaw

Citrix disclosed CVE-2019-19781 on 17 December 2019 in bulletin CTX267027 with interim mitigations (CTX267679); firmware fixes for ADC and Gateway 10.5 to 13.0 followed between 19 and 24 January 2020, and the SD-WAN WANOP fix and a Citrix and FireEye scanner for indicators came on 22 January (**Confirmed** [68]). NVD published it on 27 December at 9.8 with CWE-22 (**Confirmed** [39]). Public exploit repositories appeared on 10 and 11 January 2020; one author said it published only because others already had, and CISA's own checker repository was created minutes later (**Demonstrated** [69]). Mandiant then saw an actor exploit Citrix with a single POST request from a Tor exit node, kill rival miners and install a Go backdoor called NOTROBIN, with cron persistence seen by 12 January 2020; NOTROBIN deleted other actors' exploit files but kept a per-victim key backdoor, and nearly 100 unique keys were recovered (**Confirmed** [70]). CISA's AA20-031A gave detection guidance (traversal requests to /vpns/, a POST to a .pl file followed by a GET of an .xml file, /tmp/.init, and the nobody user's crontab) and said patching does not remediate a system that is already compromised (**Confirmed** [71]). Actors affiliated with China's Ministry of State Security later used CVE-2019-19781 against Citrix devices and reused Active Directory credentials taken through Pulse CVE-2019-11510 months after victims had patched (**Confirmed** [72]).

Mail servers: Exim

Qualys reported CVE-2019-10149, "Return of the WIZard", to Exim on 27 May 2019, and public release was brought forward to 5 June after a leak (**Confirmed** [80] [81]). Exim 4.87 to 4.91 are affected; local exploitation is immediate and runs commands as root, while remote exploitation in the default configuration needs a connection held open for about seven days. Exim 4.92, released on 10 February 2019, had fixed it silently (**Confirmed** [80]). The Exim project's notice confirms the timeline and versions, and NVD scores it 9.8 with CWE-78 (**Confirmed** [81] [39]). Sandworm exploited it from at least August 2019 (**Confirmed** as relayed [82]), and Canada's Cyber Centre reported continued exploitation and reportedly Canadian victims in June 2020, referencing its earlier alert of 14 June 2019 (**Confirmed** [83]). KEV added it on 10 January 2022 with ransomware use Unknown (**Confirmed** [66]). A second Exim flaw, CVE-2019-15846 (before 4.92.2), allowed remote code execution as root through a trailing backslash; NVD published it on 6 September 2019 at 9.8, and it is not in KEV (**Confirmed** [39]).

Atlassian Confluence and Crowd

Atlassian's 20 March 2019 advisory fixed CVE-2019-3396 (Widget Connector template injection) and CVE-2019-3395 (WebDAV server-side request forgery), both Critical, in 6.6.12, 6.12.3, 6.13.3, 6.14.2 and 6.15.1, and said nothing about exploitation. NVD scores CVE-2019-3396 at 9.8 with CWE-22 (**Confirmed** [84] [39]). Trend Micro saw it exploited from April 2019 by the AESDDoS botnet, and its 7 May write-up covered the Kerberods dropper, an XMRig miner and a rootkit that hooks readdir, stat and unlink, spreading over SSH and through Jenkins CVE-2019-1003000 and CVE-2019-1003001 (**Confirmed** [85]). Crowd CVE-2019-11580, a development plugin left enabled, was published on 3 June 2019 at 9.8 and is in KEV (**Confirmed** [39] [66]).

Embedded devices: URGENT/11

CISA's ICSA-19-211-01 of 30 July 2019 covered eleven CVEs (CVE-2019-12255 to CVE-2019-12265) in the VxWorks IPnet network stack, reported by Wind River with Armis researchers, affecting versions back to 6.5. It said no known public exploits targeted them, though they are remotely exploitable with low skill (**Confirmed** [86]). Armis described six critical remote code execution flaws it called wormable and put VxWorks in over 2 billion devices, an install base rather than an affected count; VxWorks 7 fixes shipped on 19 July, and on 1 October Armis extended the issue to OSE, INTEGRITY, ThreadX, Nucleus, ITRON and ZebOS (**Confirmed** [87]). NVD scores CVE-2019-12255 and CVE-2019-12256 at 9.8 with CWE-120; neither is in KEV, and no source opened records in-the-wild exploitation (**Confirmed** [39] [66]).

How the 2019 flaws aged

CVE	Product	NVD (score, CWE)	KEV date added	Later record
CVE-2019-11510	Pulse Connect Secure	10.0, CWE-22	2021-11-03 (ransomware Known)	Top-three exploited CVE of 2020 [73]
CVE-2019-19781	Citrix ADC and Gateway	9.8, CWE-22	2021-11-03 (Known)	Top-three exploited CVE of 2020; exploited in the wild [73] [88]
CVE-2018-13379	FortiOS SSL VPN (patched May 2019)	9.8, CWE-22	2021-11-03 (Known)	Top-three exploited CVE of 2020; device IPs sold, November 2020 [73] [79]
CVE-2019-0708	Windows RDS (BlueKeep)	9.8, CWE-416	2021-11-03 (Known)	Used by Chinese state-sponsored actors [67]
CVE-2019-11539	Pulse Connect Secure	7.2, CWE-78	2021-11-03 (Known)	
CVE-2019-0604	SharePoint	not checked	2021-11-03 (Known)	The only 2019 CVE in the 2016 to 2019 top 10 [88]; on the 2020 list [73]
CVE-2019-18935	Telerik UI	not checked	2021-11-03 (Known)	On the 2020 list [73]
CVE-2019-11580	Atlassian Crowd	9.8	2021-11-03 (Known)	On the 2020 list [73]
CVE-2019-3396	Atlassian Confluence	9.8, CWE-22	2021-11-03 (Known)	Named in the 2020 list's body [73]
CVE-2019-10149	Exim	9.8, CWE-78	2022-01-10 (Unknown)	Sandworm since August 2019 [82]
CVE-2019-2725	Oracle WebLogic	CWE-74	2022-01-10 (Known)	Sodinokibi delivery, April 2019 [38]
CVE-2019-1579	Palo Alto Networks PAN-OS (GlobalProtect)	not checked	2022-01-10 (Known)	Named in NCSC's October 2019 alert [76]
CVE-2018-13382	FortiOS SSL VPN	not checked	2022-01-10 (Known)	DEVCORE's password-reset flaw [77]
CVE-2019-15107	Webmin	not checked	2022-03-25 (Known)	
CVE-2019-16759	vBulletin	not checked	2021-11-03 (Unknown)	
CVE-2019-1652	Cisco RV320	not checked	2022-03-03 (Unknown)	
CVE-2019-5544	VMware ESXi and Horizon DaaS	not checked	2021-11-03 (Known)	
CVE-2019-1181, CVE-2019-1182	Windows RDS	9.8	Not in KEV	
CVE-2019-15846	Exim	9.8	Not in KEV	
CVE-2019-12255, CVE-2019-12256	VxWorks IPnet	9.8, CWE-120	Not in KEV	No in-the-wild record found

Sources: NVD [39], KEV catalog version 2026.11.03 [66], and the advisories cited in the last column. KEV holds 119 CVE-2019 entries (**Confirmed** [66]). The CISA and FBI top-10 for 2016 to 2019 was dominated by

Office OLE flaws, with SharePoint CVE-2019-0604 the only 2019 entry; set beside the 2020 list, the targets moved from documents to edge devices (**Confirmed** for each list [88] [73]; the reading is **Inferred**). Three further readings are this study's own (**Inferred**): for edge VPN appliances the patch-to-harm gap ran months to years, since Pulse patched in April 2019 and was still a top-two exploited flaw in 2020 and Fortinet patched in May 2019 and unpatched device addresses were being sold in November 2020 [73] [79]; patching alone did not end these incidents, because credentials harvested before the patch were reused and compromised Citrix boxes needed rebuilding [75] [71]; and the KEV launch batch of 3 November 2021 retro-tagged most of these flaws, so a KEV date added is a catalog date, not an exploitation date [66].

Part 5: supply chain, cloud and exposed data

ShadowHammer: the ASUS updater

Kaspersky first found the compromised ASUS updater on 29 January 2019 and told ASUS on 31 January. The attackers had patched a legitimate 2015 ASUS Live Updater setup.exe to launch a shellcode downloader, and Kaspersky telemetry saw the injected code on over 57,000 of its users' machines (**Confirmed** [11]). Its 25 March disclosure said the tool was backdoored at least between June and November 2018 and that more than a million users may have received it, but the real target list was several hundred users, identified by more than 600 MAC addresses across over 230 samples (**Confirmed** [12]). The payload was fetched only when a hash of a network adapter's MAC address matched hard-coded tables (14 tables, the largest with 307 entries). The binaries were signed with two genuine ASUSTeK certificates that had also signed at least 3,000 legitimate ASUS files, and Kaspersky could not say how they were obtained. The downloader contacted asushotfix[.]com for logo.jpg and logo2.jpg, and an updated ShadowPad (`S0596`) backdoor was found on a victim network (**Confirmed** [11]). The same injection style turned up in signed binaries of game developers Electronics Extreme in Thailand (Infestation) and Zepetto in South Korea (PointBlank), plus three more South Korean victims (**Confirmed** [11]).

Attribution is soft. Kaspersky's press release says the operation is probably related to the BARIUM APT, which it ties to ShadowPad and CCleaner; its technical post does not name BARIUM or APT41 (**Confirmed** [12] [11]). ATT&CK's APT41 (`G0096`) lists BARIUM as an associated name, but there is no ATT&CK campaign object for ShadowHammer in the library data, so the APT41 link stays at Kaspersky's "probably related" (**Confirmed** for the data [40]; the link is **Inferred**). APT41: The Public Record is the home for the wider APT41 attribution record.

SolarWinds begins

SolarWinds said on 11 January 2021 that the earliest suspicious activity in its environment dated to September 2019 and that its October 2019 Orion release carried test modifications. ATT&CK records the SolarWinds Compromise as campaign `C0024` from August 2019, and SUNSPOT (`S0562`) as used from at least February 2020 (**Confirmed** [123] [124]). The full story, from those test modifications to the December 2020 disclosure, lives in the SolarWinds study.

Capital One

Capital One said an outside individual reached its data on 22 and 23 March 2019 through a specific configuration vulnerability, that it got a responsible-disclosure tip on 17 July and confirmed the intrusion on 19 July. About 100 million people in the US and 6 million in Canada were affected, including about 140,000 Social Security numbers, 80,000 linked bank account numbers and about 1 million Canadian Social Insurance Numbers, from applications dating from 2005 to early 2019. It expected $100 million to $150 million in incremental 2019 costs and said the vulnerability was not specific to the cloud (**Confirmed** [89] [120]). DOJ announced the arrest of a Seattle tech worker on 29 July, describing access through a misconfigured web application firewall; a GitHub user had alerted Capital One, and FBI seized devices holding a copy of the data (**Confirmed** [90]).

The criminal complaint sets out three commands. A firewall misconfiguration let commands reach a Capital One server; the first obtained credentials for a role named *****-WAF-Role, the second listed storage buckets, and the third synced data out. A GitHub gist dated 21 April 2019 held the server's IP address, the commands and a list of more than 700 folders or buckets. The bucket listing on 22 March came from TOR exit nodes and the sync from the IPredator VPN; the complaint's early figures were about 120,000 Social Security numbers and 77,000 bank account numbers (**Confirmed** [91]). The indictment release of 28 August added that the defendant stole data from more than 30 other entities, used self-built scanning software to find cloud customers with misconfigured firewalls, and mined cryptocurrency on victims' servers, with no evidence the data was sold or spread (**Confirmed** [92]). In June 2022 a jury convicted on seven counts (wire fraud, five counts of unauthorized access and damaging a protected computer) and acquitted on access device fraud and aggravated identity theft; the sentence was not checked (**Confirmed** [93]). The OCC assessed an $80 million civil money penalty on 6 August 2020 for failing to set up effective risk assessment before moving IT operations to the public cloud, with a cease and desist order, and DOJ notes the bank settled customer suits for $190 million (**Confirmed** [94] [93]).

The mechanism most often cited, server-side request forgery through a ModSecurity firewall to the EC2 instance metadata service, comes from KrebsOnSecurity; the complaint itself never says SSRF or metadata service (**Reported** [95]). AWS shipped IMDSv2 on 19 November 2019, which requires a session token obtained by PUT, refuses requests carrying an X-Forwarded-For header and sets a response hop limit of one, as defense in depth against open firewalls, open reverse proxies and SSRF. The post does not name Capital One; the link is an inference from timing and the threats it lists (**Confirmed** [96]; the link is **Inferred**).

First American: a URL anyone could change

KrebsOnSecurity reported on 24 May 2019 that about 885 million First American title files back to 2003 could be read without authentication by changing digits in a document URL; First American cited a design defect in an application and shut off external access (**Reported** [97]). The SEC's 2021 order says the EaglePro defect had been in place since 2014 and that changing URL digits exposed other documents in a repository of about 800 million images back to 2003. A penetration test report finalized on 11 January 2019 rated it level 3, but a clerical error logged it as level 2 with a deadline of 8 May 2019, and it was not fixed; the executives who issued the 24 May statement and the 28 May Form 8-K were not told of the report (**Confirmed** [98]). The SEC settled for a $487,616 penalty over disclosure controls under Exchange Act Rule 13a-15(a), without admission or denial (**Confirmed** [99]). New York's Department of Financial Services filed charges in July 2020 as its first enforcement action under 23 NYCRR Part 500, citing six provisions and noting that an internal penetration test had found the exposure of bank account numbers, Social Security numbers, mortgage and tax records, wire receipts and driver's license images in December 2018 (**Confirmed** [100]).

Facebook: passwords, buckets and scraped phone numbers

Facebook said on 21 March 2019 that a January review had found some passwords stored readably in internal systems; it notified hundreds of millions of Facebook Lite users, tens of millions of Facebook users and, in an 18 April revision, millions of Instagram users, and said the passwords were never visible outside the company (**Confirmed** [101]). UpGuard reported two third-party Facebook app datasets on public Amazon S3: Cultura Colectiva's cc-datalake of about 146 GB and over 540 million records of comments, likes, reactions, account names and Facebook IDs, secured on 3 April after Bloomberg contacted Facebook following unanswered UpGuard emails on 10 and 14 January; and an At the Pool backup with plaintext passwords for about 22,000 users (**Confirmed** [102]). On 24 July the FTC imposed a $5 billion penalty and a 20-year order over violations of its 2012 order, including friend data shared with third-party apps and two-factor phone numbers used for advertising; the order requires scanning for plaintext passwords (**Confirmed** [103]). In September TechCrunch reported an unprotected server with more than 419 million Facebook phone-number records (about 133 million in the US, 18 million in the UK and more than 50 million in Vietnam); Facebook said the data was old, scraped before it removed phone search, and later put the count at about 220 million (**Reported** [104]). Facebook had disabled search by phone number or email in April 2018, saying most people on Facebook could have had their public profile scraped (**Confirmed** [105]). Meta said in April 2021 that a 530-million-user dataset then circulating was scraped before September 2019 through the contact importer, not by hacking (**Confirmed** [106]), and Ireland's Data Protection Commission fined it EUR 265 million under GDPR Article 25(1) and 25(2) in November 2022 for scraping between 25 May 2018 and September 2019 (**Confirmed** [107]).

National data in the open: Ecuador and Bulgaria

vpnMentor reported an exposed server in Miami, apparently owned by the Ecuadorian firm Novaestrat, holding about 18 GB on over 20 million people, some deceased: national ID and taxpayer numbers, family members, bank details, employment and salary, and vehicle records, including an entry for Julian Assange. It was closed on 11 September 2019; the page does not name the database engine (**Confirmed** [108]). Ecuador's prosecutors opened an investigation, raided the home of Novaestrat's legal representative and seized equipment (**Reported** [109]); The Register reported an executive's arrest, about 7 million minors in the data, and the president's wish to speed up a draft data protection law (**Reported** [110]). Bulgaria's National Revenue Agency was breached on 15 July 2019, exposing data on over 5 million citizens; the data protection commission announced a BGN 5.1 million fine on 29 August and fined DSK Bank BGN 1 million the same day (**Reported** [111]).

Part 6: the government and legal record

Date	Body	Action	2019 event	Grade	Source
2019-01-22	CISA	Emergency Directive 19-01 on DNS tampering	DNS hijacking campaigns	Confirmed	[118]
2019-02-18	Australian Prime Minister	Statement to Parliament on the Parliament House intrusion	Parliament network	Confirmed	[17]
2019-03-27	US District Court for DC, on Microsoft's motion	Order transferring 99 Phosphorus domains, made the week before and unsealed and announced on 2019-03-27	Phosphorus	Confirmed	[20]
2019-04-10, 2019-05-09	DHS and FBI	HOPLIGHT and ELECTRICFISH malware analyses	Lazarus Group tooling	Confirmed	[26] [27]
2019-06-17	CISA	AA19-168A on BlueKeep	CVE-2019-0708	Confirmed	[62]
2019-06-22	CISA Director	Statement on Iranian threats	Wiper activity	Confirmed	[18]
2019-06-22	UK NCSC	Ryuk advisory	Ryuk	Confirmed	[42] [43]
2019-07-24	FTC	$5 billion penalty and 20-year order	Facebook	Confirmed	[103]
2019-07-29, 2019-08-28	DOJ (W.D. Washington)	Arrest and indictment	Capital One	Confirmed	[90] [92]
2019-08-29	Bulgaria's data protection commission	BGN 5.1 million fine	National Revenue Agency	Reported	[111]
2019-08-30	UN Panel of Experts	S/2019/691	DPRK theft	Confirmed	[28]
2019-09-10	FBI	BEC PSA; Operation reWired	BEC	Confirmed	[49] [50]
2019-09-13	US Treasury	Designations of Lazarus Group, Bluenoroff and Andariel	DPRK theft	Confirmed	[29]
2019-10-02	UK NCSC; FBI	VPN alert; ransomware PSA	VPN flaws; ransomware	Confirmed	[76] [52]
2019-10-07	NSA	VPN advisory (via relay)	VPN flaws	Confirmed (relay)	[58]
2019-10-21	UK NCSC with NSA	Turla advisory	Turla	Confirmed	[7]
2019-12-05	US Treasury; FBI and DOJ	Evil Corp sanctions; charges against Yakubets and Turashev	Dridex	Confirmed	[5] [55]
2020-02-20	UK FCO and NCSC; US State Department	Attribution to GRU GTsST	Georgia	Confirmed	[1] [2]
2020-05-28	NSA, relayed by CISA	Sandworm Exim advisory	CVE-2019-10149	Confirmed	[82]
2020-07-22	NY DFS	First Part 500 enforcement action	First American	Confirmed	[100]
2020-08-06	OCC	$80 million penalty, cease and desist	Capital One	Confirmed	[94]
2021-06-14 to 15	SEC	Order and $487,616 penalty	First American	Confirmed	[98] [99]

Date	Body	Action	2019 event	Grade	Source
2021-10-26	Europol-coordinated police action	Raids on 12 suspects	LockerGoga, MegaCortex, Dharma	Reported	[37]
2021-11-08	US Treasury	Designations of Polyanin and Vasinskyi	REvil	Confirmed	[48]
2022-06-17	Federal jury	Conviction on seven counts	Capital One	Confirmed	[93]
2022-11-28	Irish Data Protection Commission	EUR 265 million fine	Facebook scraping	Confirmed	[107]

The record shows a pattern: 2019's malware analyses and directives came within weeks of the activity, while attributions, charges and fines took months to years (**Inferred** from the dates above).

A library correction. The library's Notable Incidents page lists "Sandworm/TrickBot operators" as sanctioned in September 2019. The 13 September 2019 Treasury action designated Lazarus Group, Bluenoroff and Andariel, all North Korean (**Confirmed** [29] [125]). The line should be corrected in a separate change.

Part 7: the defender view

What 2019 changed in practice

Edge devices are the perimeter. NCSC's two essential steps for a VPN exposed to these flaws were to patch and to reset credentials, then to check configuration, SSH authorized keys and iptables for changes (**Confirmed** [76]). CISA's Pulse cases show why the credential step matters: actors returned with harvested credentials after the patch (**Confirmed** [75]). CISA's Citrix guidance shows why the check matters: an established actor survives the patch (**Confirmed** [71]). Verizon's DBIR covering November 2018 to October 2019 found web applications in 43 percent of breaches and stolen or used credentials in 37 percent (**Confirmed** [117]).

Ransomware is an intrusion, not an infection. CrowdStrike's 2019 breakout time of 9 hours for eCrime actors is the window between first foothold and lateral movement, up from 4 hours 37 minutes in 2018 (**Confirmed** [116]). Emotet and TrickBot detections, PsExec pushes, vssadmin shadow-copy deletion and service-stop scripts are all observable before encryption (**Confirmed** [32] [44]). Backups and a manual-operations plan decide the outcome after it: Hydro restored from backups and ran plants by hand, and FBI named backups the most important defense (**Confirmed** [35] [52]).

Cloud identity is the cloud perimeter. In the Capital One complaint the attacker's every step after the firewall used a legitimate role's credentials: list buckets, then sync (**Confirmed** [91]). Verizon found cloud assets in about 24 percent of breaches, 77 percent of those with breached credentials (**Confirmed** [117]). IMDSv2 removes the simplest path from a forwarded request to role credentials (**Confirmed** [96]).

DNS and certificates are attack surface. ED 19-01's four actions (audit DNS records, change DNS account passwords, add multi-factor authentication, watch Certificate Transparency logs) remain a complete first response to registrar-level hijacking (**Confirmed** [118]; the "complete" judgement is **Inferred**).

Hunting leads published in the 2019 primaries

Lead	What to look for	Source
Citrix CVE-2019-19781	Traversal requests to /vpns/; a POST to a .pl file followed by a GET of an .xml file; /tmp/.init; entries in the nobody user's crontab	[71]
Pulse CVE-2019-11510 follow-on	Logons with valid accounts from Tor or rented servers after the patch date; new scheduled tasks; LogMeIn or TeamViewer installs	[75]
VPN appliances generally	Configuration changes, unexpected SSH authorized keys, iptables changes; logons from unusual locations or times	[76]
TrickBot anchor_dns	DNS command traffic using the single-byte XOR key 0xB9	[44]
Ryuk staging	PsExec service creation across many hosts, kill.bat service stops, vssadmin shadow-copy deletion, RDP fan-out	[32] [44]
Sodinokibi via WebLogic	PowerShell and certutil downloads on WebLogic servers	[38]
BlueKeep	Spikes in RDP service crashes on exposed hosts	[64]
Capital One pattern	Bucket listing then bulk sync by an instance role, from TOR or commercial VPN addresses	[91]
Sea Turtle and DNS hijacking	Certificates in CT logs for your domains that you did not request; changed DNS records at the registrar	[118] [25]
TRITON actor	Tools named like Microsoft updates or vendor applications, timestomped files, encrypted SSH tunnels, off-hours activity, modified OWA files	[30]
Turla's borrowed infrastructure	ASPX web shell scanning against your web servers	[7]

Where the library's countermeasure data fits

The D3FEND countermeasures that match the 2019 advice are listed in Part 8. Two gaps are worth naming: the library data maps Software Update (`D3-SU`) to 35 techniques, among them `T1195.002` and `T1490`, but not to `T1190`, so the main fix for every edge flaw in Part 4 is not linked from the technique it defends against, and no technique-level CAPEC exists in the library data for `T1190`, `T1486` or `T1552.005` (**Confirmed** [40]).

Part 8: MITRE mappings

This part binds the verified record to MITRE ATT&CK v20.0, CAPEC, CWE and D3FEND. Every id was checked against the live ATT&CK pages or the library's data files on 3 November 2026, and every linked page exists in the library's `mitre/` tree; ids that could not be checked are left out (**Confirmed** [40]). The 2019 sources use pre-v7 ids; they appear here under their v20.0 ids as `data/attack/superseded_by.jsonl` records them (for example T1089 to `T1685`, T1086 to `T1059.001`, `T1574.002` to `T1574.001`, `T1656` to `T1684.001`) (**Confirmed** [115]).

The "Basis" column says how each row is supported. **ATT&CK** means the library's ATT&CK data records the technique for the group, software or campaign named, checked in `group_to_technique.jsonl`, `software_to_technique.jsonl` or `campaign_profiles.jsonl`; that record is not always dated to 2019. **Primary** means an opened primary describes the behavior and this study chose the id. **Reported** means the

behavior is known only from a secondary source. **Inferred** means the id choice itself is a judgement.

Enterprise techniques

ID	Technique	Tactic (v20)	2019 event or report (date)	Basis	Sources
T1590.001	Gather Victim Network Information: Domain Properties	Reconnaissance	Sandworm reconnaissance of the Parliament of Georgia domain before 2019-10-28	ATT&CK (G0034, dated to Georgia)	[119]
T1595.002	Active Scanning: Vulnerability Scanning	Reconnaissance	Capital One defendant's self-built scanner for misconfigured cloud firewalls (2019-08-28)	Primary	[92]
T1589	Gather Victim Identity Information	Reconnaissance	Phosphorus researched personal data and phone numbers (2019-10-04)	Primary; ATT&CK (G0059)	[21]
T1598.003	Phishing for Information: Spearphishing Link	Reconnaissance	Phosphorus fake security alerts leading to credential forms (2019-03-27)	Primary; ATT&CK (G0059)	[20]
T1583.001	Acquire Infrastructure: Domains	Resource Development	Phosphorus lookalike domains, 99 seized (announced 2019-03-27)	Primary; ATT&CK (G0059)	[20]
T1584	Compromise Infrastructure	Resource Development	Turla's takeover of OilRig command infrastructure (2019-06-20, 2019-10-21)	Inferred	[9] [7]
T1584.002	Compromise Infrastructure: DNS Server	Resource Development	Sea Turtle (2019-04-17); ED 19-01 (2019-01-22)	ATT&CK (G1041)	[25] [118]
T1588.004	Obtain Capabilities: Digital Certificates	Resource Development	Valid certificates for hijacked names (ED 19-01, Sea Turtle)	ATT&CK (G1041)	[118] [25]
T1608.003	Stage Capabilities: Install Digital Certificate	Resource Development	Sea Turtle (2019-04-17)	ATT&CK (G1041)	[25]
T1190	Exploit Public-Facing Application	Initial Access	Sodinokibi via WebLogic (2019-04-17); Sea Turtle known CVEs; GALLIUM via WildFly/JBoss (2019-12-12); APT VPN exploitation (2019-10-02); Sandworm Exim (from 2019-08); Confluence (from 2019-04); BlueKeep coin-miner campaign (from 2019-10-23); Capital One firewall (2019-03-22)	Primary; ATT&CK (G0034, G1041, G0093)	[38] [25] [15] [76] [82] [85] [64] [91]
T1133	External Remote Services	Initial Access, Persistence	VPN access with stolen credentials (NCSC, 2019-10-02); RDP access for ransomware (FBI, 2019-10-02); Wocao legitimate VPN access (2019-12-19); APT10 Citrix with stolen credentials (2019-02-06)	Primary; ATT&CK (C0014); Reported (APT10)	[76] [52] [16] [13]

ID	Technique	Tactic (v20)	2019 event or report (date)	Basis	Sources
T1078	Valid Accounts	Initial Access, Persistence, Privilege Escalation, Stealth	Credentials read from VPNs and reused (NCSC; AA20-107A); CrowdStrike's 2019 technique prose	Primary; ATT&CK (C0014)	[76] [75] [116]
T1078.001	Valid Accounts: Default Accounts	Initial Access, Persistence, Privilege Escalation, Stealth	STRONTIUM IoT devices with default passwords (2019-04)	Primary	[3]
T1078.004	Valid Accounts: Cloud Accounts	Initial Access, Persistence, Privilege Escalation, Stealth	Capital One WAF-Role credentials (2019-03-22)	Primary	[91]
T1566	Phishing	Initial Access	Iranian spear phishing enabling wipers (CISA, 2019-06-22); Sea Turtle	Primary	[18] [25]
T1566.001	Phishing: Spearphishing Attachment	Initial Access	Ransomware by email with a malicious file (FBI, 2019-10-02); Emotet Word attachments (2019-09-16)	Primary; ATT&CK (S0367, S0266, S0496)	[52] [41]
T1566.002	Phishing: Spearphishing Link	Initial Access	FBI ransomware PSA (2019-10-02); Phosphorus spear phishing (2019-03-27)	Primary; ATT&CK (G0059)	[52] [20]
T1199	Trusted Relationship	Initial Access	MSP remote tools used against customers of at least three MSPs (FBI, 2019-10-02); Sea Turtle via third-party DNS providers; Texas via an MSP (2019-08-16); APT10's aim at Visma's clients	Primary; ATT&CK (G1041); Reported (Texas, APT10)	[52] [25] [47] [13]
T1195.002	Supply Chain Compromise: Compromise Software Supply Chain	Initial Access	ASUS Live Update (disclosed 2019-03-25); SolarWinds Orion test modifications (2019-10)	Primary; ATT&CK (C0024)	[11] [12] [123]
T1059.001	Command and Scripting Interpreter: PowerShell	Execution	CrowdStrike 2019 list; Ryuk with PowerShell Empire; Sodinokibi downloads; Waterbug registry-stored PowerShell	Primary	[116] [32] [38] [9]
T1059.003	Command and Scripting Interpreter: Windows Command Shell	Execution	CrowdStrike's "Command-Line Interface" (2019 list)	Inferred (sub-technique choice)	[116] [115]
T1203	Exploitation for Client Execution	Execution	Elfin WinRAR CVE-2018-20250 (2019-02)	Primary; ATT&CK (G0064)	[19]
T1204.002	User Execution: Malicious File	Execution	Emotet infected Word attachments (2019-09-16)	Primary; ATT&CK (S0367)	[41]
T1569.002	System Services: Service Execution	Execution	Ryuk pushed with PsExec (2019-01-10); GALLIUM PsExec (2019-12-12)	Primary	[32] [15]

ID	Technique	Tactic (v20)	2019 event or report (date)	Basis	Sources
T1047	Windows Management Instrumentation	Execution	Ryuk toolkit (AA20-302A); Soft Cell	Primary; Reported (Soft Cell)	[44] [14]
T1053.005	Scheduled Task/Job: Scheduled Task	Execution, Persistence, Privilege Escalation	Ryuk toolkit; Pulse follow-on persistence	Primary	[44] [75]
T1053.003	Scheduled Task/Job: Cron	Execution, Persistence, Privilege Escalation	NOTROBIN on Citrix CVE-2019-19781 victims (by 2020-01-12)	Primary	[70]
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder	Persistence, Privilege Escalation	CrowdStrike 2019 list; earlier Ryuk builds	Primary	[116] [32]
T1543.003	Create or Modify System Process: Windows Service	Persistence, Privilege Escalation	Ryuk toolkit (AA20-302A)	Primary	[44]
T1505.003	Server Software Component: Web Shell	Persistence	GALLIUM China Chopper and BlackMould (2019-12-12); TRITON actor OWA web shells (2019-04-10); Turla ASPX web shell scanning (2019-10-21); ZeroCleare ASPX web shells	Primary; ATT&CK (G0093); Reported (ZeroCleare)	[15] [30] [7] [22]
T1574.001	Hijack Execution Flow: DLL	Stealth, Execution	APT10 Trochilus by DLL side-loading (reported under T1574.002)	Reported	[13] [115]
T1014	Rootkit	Stealth	Kerberods rootkit on Confluence victims (2019-05-07)	Primary	[85]
T1036	Masquerading	Stealth	CrowdStrike: the biggest rise of 2019	Primary	[116]
T1036.005	Masquerading: Match Legitimate Resource Name or Location	Stealth	TRITON actor tools named like Microsoft updates and a Schneider Electric application (2019-04-10); APT10 renamed WinRAR and cURL	Primary; Reported (APT10)	[30] [13]
T1055	Process Injection	Stealth, Privilege Escalation	CrowdStrike 2019 list	Primary	[116]
T1564.001	Hide Artifacts: Hidden Files and Directories	Stealth	CrowdStrike 2019 list	Primary	[116]
T1070.006	Indicator Removal: Timestomp	Stealth	TRITON actor (2019-04-10)	Primary	[30]
T1027	Obfuscated Files or Information	Stealth	Waterbug Base64 PowerShell stored in the registry (2019-06-20)	Inferred	[9]

ID	Technique	Tactic (v20)	2019 event or report (date)	Basis	Sources
T1480	Execution Guardrails	Stealth	ShadowHammer MAC-hash gating (2019-04-23); APT41 follow-on malware gated on system identifiers (2019-08-07)	Primary	[11] [10]
T1684.001	Social Engineering: Impersonation	Stealth	Fraudulent payment directions at Toyota Boshoku (2019-08-14); BEC (2019-09-10)	Inferred	[45] [49]
T1553.002	Subvert Trust Controls: Code Signing	Defense Impairment	Two ASUSTeK certificates (2019-04-23); APT41 stolen certificates (2019-08-07)	Primary	[11] [10]
T1685	Disable or Modify Tools	Defense Impairment	CrowdStrike "Disabling Security Tools" (2019 list); security-tool removal in the Ryuk toolkit	Primary; ATT&CK (S0372, S0400, S0446, S0496, S0449, S0576, S0266)	[116] [44] [40]
T1003	OS Credential Dumping	Credential Access	CrowdStrike 2019 list; Mimikatz in Waterbug, GALLIUM, Elfin, TRITON actor and Ryuk records	Primary	[116] [9] [15] [19] [30] [44]
T1555	Credentials from Password Stores	Credential Access	Elfin LaZagne (2019-03-27)	Primary; ATT&CK (G0064)	[19]
T1110	Brute Force	Credential Access	RDP brute force (FBI, 2019-10-02)	Primary	[52]
T1110.003	Brute Force: Password Spraying	Credential Access	Iranian actors (CISA, 2019-06-22); ZeroCleare summer 2019 spray	Primary; ATT&CK (G0064); Reported (ZeroCleare)	[18] [22]
T1110.004	Brute Force: Credential Stuffing	Credential Access	Iranian actors (CISA, 2019-06-22)	Primary	[18]
T1111	Multi-Factor Authentication Interception	Credential Access	Wocao abuse of 2FA soft tokens (2019-12-19)	Primary; ATT&CK (C0014)	[16]
T1557	Adversary-in-the-Middle	Credential Access, Collection	Redirected and intercepted traffic (ED 19-01, 2019-01-22)	ATT&CK (G1041)	[118]
T1552.005	Unsecured Credentials: Cloud Instance Metadata API	Credential Access	Capital One (2019-03-22); ATT&CK's procedure cites a news article	Reported	[95] [121]
T1040	Network Sniffing	Credential Access, Discovery	STRONTIUM ran tcpdump on compromised devices (2019-04); MESSAGETAP (home: APT41: The Public Record)	Primary	[3] [124]
T1087	Account Discovery	Discovery	CrowdStrike 2019 list	Primary	[116]
T1033	System Owner/User Discovery	Discovery	CrowdStrike 2019 list	Primary	[116]

ID	Technique	Tactic (v20)	2019 event or report (date)	Basis	Sources
T1069	Permission Groups Discovery	Discovery	STRONTIUM enumerated administrative groups (2019-04)	Primary	[3]
T1046	Network Service Discovery	Discovery	GALLIUM NBTscan (2019-12-12)	Primary	[15]
T1016	System Network Configuration Discovery	Discovery	ShadowHammer read adapter MAC addresses (2019-04-23)	Primary	[11]
T1619	Cloud Storage Object Discovery	Discovery	Capital One bucket listing (2019-03-22)	Primary	[91]
T1021.001	Remote Services: Remote Desktop Protocol	Lateral Movement	Ryuk RDP lateral movement (2019-01-10; AA20-302A)	Primary	[32] [44]
T1021.004	Remote Services: SSH	Lateral Movement	Kerberods spreading over SSH (2019-05-07)	Primary	[85]
T1530	Data from Cloud Storage	Collection	Capital One sync (2019-03-22)	Primary	[91]
T1560.001	Archive Collected Data: Archive via Utility	Collection	GALLIUM WinRAR (2019-12-12)	Primary; ATT&CK (G0093)	[15]
T1102.001	Web Service: Dead Drop Resolver	Command and Control	PolyglotDuke C2 addresses from Twitter, Reddit and Imgur (2019-10-17)	ATT&CK (S0518)	[4]
T1102.002	Web Service: Bidirectional Communication	Command and Control	RegDuke over Dropbox (2019-10-17)	ATT&CK (C0023)	[4]
T1001.002	Data Obfuscation: Steganography	Command and Control	PolyglotDuke image steganography (2019-10-17)	ATT&CK (C0023)	[4]
T1001.003	Data Obfuscation: Protocol or Service Impersonation	Command and Control	HOPLIGHT fake TLS handshakes (2019-04-10)	Primary	[26]
T1090	Proxy	Command and Control	HOPLIGHT proxies; ELECTRICFISH proxy authentication; GALLIUM HTRAN	Primary; ATT&CK (S0376)	[26] [27] [15]
T1090.003	Proxy: Multi-hop Proxy	Command and Control	Capital One bucket listing from TOR (2019-03-22); NOTROBIN from a Tor exit node; Pulse follow-on over Tor	Primary	[91] [70] [75]
T1572	Protocol Tunneling	Command and Control	ELECTRICFISH (2019-05-09); TRITON actor encrypted SSH tunnels with PLINK (2019-04-10)	Primary	[27] [30]
T1105	Ingress Tool Transfer	Command and Control	Waterbug and Sodinokibi certutil downloads; ShadowHammer payload fetch	Primary	[9] [38] [11]

ID	Technique	Tactic (v20)	2019 event or report (date)	Basis	Sources
T1071.004	Application Layer Protocol: DNS	Command and Control	TrickBot anchor_dns (early 2019)	Primary	[44]
T1219	Remote Access Tools	Command and Control	LogMeIn and TeamViewer after Pulse exploitation	Primary	[75]
T1567.002	Exfiltration Over Web Service: Exfiltration to Cloud Storage	Exfiltration	Waterbug to Box over WebDAV (2019-06-20); APT10 to the Dropbox API	Primary; Reported (APT10)	[9] [13]
T1486	Data Encrypted for Impact	Impact	Norsk Hydro (2019-03-19); Ryuk, REvil, Maze, LockerGoga, MegaCortex, RobbinHood, BitPaymer	Primary; ATT&CK (S0372, S0446, S0496, S0449, S0576, S0400, S0570)	[35] [40]
T1490	Inhibit System Recovery	Impact	Ryuk and Sodinokibi vssadmin shadow-copy deletion	Primary; ATT&CK (S0446, S0496, S0449, S0576, S0400, S0570)	[32] [38] [40]
T1489	Service Stop	Impact	Ryuk kill.bat (2019-01-10)	Primary; ATT&CK (S0446, S0496, S0449, S0576, S0400)	[32] [44] [40]
T1531	Account Access Removal	Impact	LockerGoga (Hydro, per NSM)	ATT&CK (S0372, S0576)	[124] [40]
T1491.002	Defacement: External Defacement	Impact	Georgia, about 15,000 websites (2019-10-28)	ATT&CK (G0034, dated to Georgia)	[119] [1]
T1499	Endpoint Denial of Service	Impact	Georgia, disruption after a hosting provider compromise (2019-10-28)	ATT&CK (G0034, dated to Georgia)	[119]
T1485	Data Destruction	Impact	Iranian destructive wipers (CISA, 2019-06-22)	Inferred	[18]
T1561.002	Disk Wipe: Disk Structure Wipe	Impact	ZeroCleare (2019-12-05); Dustman (2019-12-29)	ATT&CK (S1151); Reported (Dustman)	[23] [22] [24]
T1496.001	Resource Hijacking: Compute Hijacking	Impact	BlueKeep coin miner (2019-11); Confluence XMRig (2019-05-07); Capital One defendant's mining (2019-08-28); DPRK cryptocurrency mining (2019-08-30)	Primary	[64] [85] [92] [28]
T1657	Financial Theft	Impact	DPRK theft (2019-08-30, 2019-09-13); Dridex theft (2019-12-05); BEC losses (2019-09-10)	Primary	[28] [29] [5] [49]

Left out on purpose: `T1210` Exploitation of Remote Services for BlueKeep, because no opened source shows 2019 use for lateral movement (the in-the-wild campaign in Part 4 was against exposed hosts and is under `T1190`); T1064 Scripting, deprecated with no successor; and the data exposures at First American, Facebook,

Ecuador and Bulgaria, which have no adversary procedure to map (**Confirmed** [115]; the choices are **Inferred**).

ICS and Mobile

The TRITON actor's 2019 report describes IT-side tradecraft on the way to a safety system and maps to the Enterprise rows above; no ATT&CK for ICS technique is mapped, because the opened report does not describe action on the safety controller in the second facility. The 2017 Triton attack is ATT&CK campaign `C0030` (**Confirmed** [31]). URGENT/11 had no recorded in-the-wild use (Part 4). No Mobile technique is supported by the record.

Groups, campaigns and software

Object	ID	2019 role in this study	Source
Sandworm Team	G0034	Georgia (2019-10-28); Exim from 2019-08	[119] [82]
APT28	G0007	STRONTIUM corporate IoT intrusions (2019-04)	[3]
APT29	G0016	Operation Ghost; SolarWinds from 2019-09 (per ATT&CK C0024)	[4] [123] [124]
Turla	G0010	Waterbug; use of Iranian tools	[9] [7]
OilRig	G0049	Crambus and Poison Frog, taken over by Turla (Inferred link); ZeroCleare collaborator per ATT&CK	[9] [7] [23]
VOID MANTICORE	G1055	ZeroCleare per ATT&CK	[23]
APT33	G0064	Elfin	[19]
Magic Hound	G0059	Phosphorus	[20] [21]
APT41	G0096	FireEye report (home: APT41: The Public Record); BARIUM alias for the ShadowHammer link (Inferred)	[10] [12]
menuPass	G0045	APT10 at Visma (Reported)	[13]
GALLIUM	G0093	Telecom targeting; Soft Cell per ATT&CK	[15] [40]
Sea Turtle	G1041	DNS hijacking	[25]
Lazarus Group	G0032	HOPLIGHT; Treasury designation	[26] [29]
APT38	G0082	Bluenoroff, designated by Treasury	[29] [40]
Andariel	G0138	Designated by Treasury	[29]
TEMP.Veles	G0088	TRITON actor	[30] [31]
Wizard Spider	G0102	Ryuk and TrickBot	[32] [116]
GOLD SOUTHFIELD	G0115	REvil operators (PINCHY SPIDER)	[116] [40]
Indrik Spider	G0119	Evil Corp alias in the library data; BitPaymer and Dridex	[5] [40]
Operation Ghost	C0023	APT29, to October 2019	[4] [40]
Operation Wocao	C0014	To December 2019	[16] [40]
SolarWinds Compromise	C0024	From August 2019 (home: SolarWinds study)	[123] [124]
Triton Safety Instrumented System Attack	C0030	The 2017 attack; context for the 2019 report	[31]
Frankenstein; Operation Sharpshooter; Operation Dream Job	C0001, C0013, C0022	ATT&CK dates them to 2019; not covered by an opened primary here	[40]

Object	ID	2019 role in this study	Source
Ryuk; TrickBot; Emotet	S0446, S0266, S0367	The big game hunting pipeline	[32] [41]
LockerGoga; MegaCortex; RobbinHood	S0372, S0576, S0400	Hydro (per NSM); Europol 2021 action; CrowdStrike's late-2019 list (ATT&CK names Baltimore on S0400)	[36] [37] [116] [124]
REvil; Maze; BitPaymer; Dridex	S0496, S0449, S0570, S0384	Sodinokibi, Texas, Travelex; leak extortion; Evil Corp	[38] [53] [5]
Empire; Mimikatz; PsExec	S0363, S0002, S0029	Ryuk operators; credential dumping across the record; Ryuk, GALLIUM and Dustman spread	[32] [15] [24]
ShadowPad	S0596	ShadowHammer follow-on backdoor	[11]
HOPLIGHT	S0376	Lazarus Group proxy tool	[26]
ZeroCleare	S1151	Iranian wiper	[23]
PolyglotDuke; RegDuke; FatDuke; MiniDuke	S0518, S0511, S0512, S0051	Operation Ghost	[4]
POWRUNER	S0184	Crambus tool used to pull Turla's Mimikatz	[9]
China Chopper; PoisonIvy; HTRAN; NBTscan; Windows Credential Editor	S0020, S0012, S0040, S0590, S0005	GALLIUM and Soft Cell tooling	[15] [14]
LaZagne; Remcos; DarkComet; QuasarRAT; Pupy; NanoCore	S0349, S0332, S0334, S0262, S0192, S0336	Elfin tooling	[19]
UPPERCUT	S0275	APT10 at Visma (Reported)	[13]
certutil	S0160	Waterbug and Sodinokibi downloads	[9] [38]
MESSAGETAP; SUNSPOT	S0443, S0562	Linked for their home studies	[124]

No ATT&CK object exists in the library data for ShadowHammer, ELECTRICFISH, GandCrab, DoppelPaymer, Dharma, Nemty, NOTROBIN, Neuron or Nautilus, and the library has no page for Triton (`S1009`), so none is linked (**Confirmed** [40]). APT20, Fox-IT's medium-confidence match for Wocao, has no ATT&CK group object in the library data (**Confirmed** [40]).

CWE and CAPEC

CWE ids come from NVD for each CVE in Part 4 (**Confirmed** [39]). CAPEC links come from the library's `data/weaknesses/cwe.jsonl` and from the `capec` field of `data/attack/technique_profiles.jsonl` (**Confirmed** [40]). See the CWE Reference and CAPEC Reference.

Weakness	2019 record	CAPEC patterns linked in the library data
CWE-22 Path Traversal	CVE-2019-11510, CVE-2018-13379, CVE-2019-19781, CVE-2019-3396	CAPEC-126 Path Traversal, which lists CWE-22 [127]; also CAPEC-64, CAPEC-76, CAPEC-78, CAPEC-79

Weakness	2019 record	CAPEC patterns linked in the library data
CWE-78 OS Command Injection	CVE-2019-11539, CVE-2019-10149	CAPEC-88 OS Command Injection; CAPEC-6, CAPEC-15, CAPEC-43, CAPEC-108
CWE-74 Injection	CVE-2019-2725	A broad class with many patterns; see the CWE Reference
CWE-120 Classic Buffer Overflow	CVE-2019-12255, CVE-2019-12256	CAPEC-100 Overflow Buffers, among others in the library data
CWE-416 Use After Free	CVE-2019-0708	None in the library data
CWE-918 Server-Side Request Forgery	Capital One mechanism (**Reported** [95])	CAPEC-664 Server Side Request Forgery
CWE-639 Authorization Bypass Through User-Controlled Key	First American URL digits (**Inferred** from [98])	None in the library data
CWE-256 Plaintext Storage of a Password	Facebook internal password logs; At the Pool backup (**Inferred** from [101] [102])	None in the library data

Technique (2019 use)	CAPEC patterns linked in the library data
`T1133` External Remote Services (VPN and RDP access)	CAPEC-555 Remote Services with Stolen Credentials
`T1078` Valid Accounts; `T1078.001` Default Accounts	CAPEC-560 Use of Known Domain Credentials; CAPEC-70 Try Common or Default Usernames and Passwords
`T1110`, `T1110.003`, `T1110.004` (RDP brute force, Iranian spraying and stuffing)	CAPEC-112 Brute Force; CAPEC-565 Password Spraying; CAPEC-600 Credential Stuffing
`T1557` Adversary-in-the-Middle (ED 19-01)	CAPEC-94 Adversary in the Middle
`T1566.001`, `T1566.002` Spearphishing	CAPEC-163 Spear Phishing
`T1195.002` Compromise Software Supply Chain (ASUS, SolarWinds)	CAPEC-186 Malicious Software Update; also CAPEC-442, CAPEC-443, CAPEC-523, CAPEC-669, CAPEC-673, CAPEC-678 and CAPEC-691 in the library data
`T1553.002` Code Signing (ASUSTeK certificates)	CAPEC-206 Signing Malicious Code; also CAPEC-68 and CAPEC-473
`T1505.003` Web Shell	CAPEC-650 Upload a Web Shell to a Web Server
`T1574.001` DLL (APT10 side-loading)	CAPEC-471 Search Order Hijacking; CAPEC-641 DLL Side-Loading
`T1014` Rootkit (Kerberods)	CAPEC-552 Install Rootkit
`T1001.002` Steganography (PolyglotDuke)	CAPEC-636 Hiding Malicious Data or Code within Files
`T1036` Masquerading	CAPEC-177 Create files with the same name as files protected with a higher classification

Technique (2019 use)	CAPEC patterns linked in the library data
T1055 Process Injection	CAPEC-251 Local Code Inclusion; CAPEC-660 Root/Jailbreak Detection Evasion via Hooking
T1685 Disable or Modify Tools	CAPEC-571 Block Logging to Central Repository; CAPEC-578 Disable Security Software
T1531 Account Access Removal (LockerGoga)	CAPEC-2 Inducing Account Lockout
T1499 Endpoint Denial of Service (Georgia)	CAPEC-125, CAPEC-131 and CAPEC-227 in the library data

T1584.002 maps to CAPEC-142 (DNS Cache Poisoning) in the library data, but Sea Turtle and ED 19-01 describe record tampering through stolen registrar or DNS account credentials, not cache poisoning, so CAPEC-142 is left out for this event (**Inferred** judgement [40]). T1190, T1486 and T1552.005 have no CAPEC in the library data.

D3FEND countermeasures

These countermeasure pages exist in the library and match the mitigations the 2019 primaries published (**Confirmed** [40]). Where the library's technique_to_d3fend.jsonl maps the countermeasure to a technique, the table says so; otherwise the fit is the source's advice. See the D3FEND Reference.

2019 advice	Techniques	D3FEND countermeasure	Basis	Source
Patch the edge flaws	T1190	Software Update (D3-SU)	Source advice; the library maps D3-SU to 35 techniques (including T1195.002, T1490) but not T1190	[76] [58]
Reset credentials after patching	T1078, T1133	Credential Rotation (D3-CRO), Credential Revocation (D3-CR)	Source advice	[76]
Two-factor on VPN, RDP and DNS accounts	T1133, T1110, T1584.002	Multi-factor Authentication (D3-MFA)	Source advice	[76] [52] [118]
Watch Certificate Transparency logs	T1588.004, T1608.003	Certificate Analysis (D3-CA)	Source advice	[118]
Audit DNS records	T1584.002	DNS Traffic Analysis (D3-DNSTA)	Inferred closest fit	[118]
Look for logons from odd places or times	T1190, T1021.001	User Geolocation Logon Pattern Analysis (D3-UGLPA)	Library maps it to T1190 and T1021.001	[76]
Audit, close and log RDP	T1021.001, T1133	Remote Terminal Session Detection (D3-RTSD), Disable Remote Access (D3-DRA)	Source advice	[52]
Restore from offline backups	T1486, T1490	Restore File (D3-RF), Restore Software (D3-RS)	Library maps D3-RF to T1486 and D3-RS to T1490	[35] [52]
Application allowlisting	T1204.002, T1569.002	Executable Allowlisting (D3-EAL)	Source advice	[52]

Navigator layer

The study's Enterprise techniques are collected in an ATT&CK Navigator layer, `navigator/library-layers/chronicle-2019.json`, listed with the library's other curated layers on the Navigator layers page. Open it in the ATT&CK Navigator. Scores mean evidence basis, not frequency or severity: 100 where the library's ATT&CK data records the technique for an object in this study, 70 where an opened primary describes the behavior and the study chose the id, and 40 where the behavior is only Reported or the id choice is Inferred. Each technique's comment names the study's source numbers; the layer follows the format the library's validator enforces [126].

Cross-cutting themes

The time between patch and harm. BlueKeep went from patch (14 May) to public exploit (6 September) to the first in-the-wild campaign (23 October) in about five months. Pulse went from patch (24 April) to public exploit code (late August) to a top-two exploited flaw of 2020. Citrix went from advisory (17 December) to public exploit (10 January) in under four weeks, before the firmware fixes shipped (**Confirmed** dates [61] [63] [64] [58] [73] [68] [69]; the comparison is **Inferred**). Fear and harm did not match: BlueKeep was feared as a worm and used for mining, while the flaws that did the damage were path-traversal bugs on VPN and gateway appliances (**Inferred**).

Crime and state blur. Treasury said Evil Corp's leader worked for the FSB; FireEye described APT41 doing espionage and crime at once; the UN Panel of Experts was investigating at least 35 reported DPRK attacks on financial institutions and cryptocurrency exchanges, with some estimates of proceeds as high as $2 billion (**Confirmed** [5] [10] [28]). For a defender the practical result is that "criminal" and "state" are not separate threat models: the same exposed VPN serves both (**Inferred**).

Actors inside actors. Turla's use of Iranian tools and command panels means that indicators and even tools are weak evidence of who is behind an intrusion (the facts **Confirmed** [7]; the lesson **Inferred**).

The supply chain and the service provider. ShadowHammer, the first steps of SolarWinds, APT10's aim at Visma's clients, the Texas MSP route and FBI's three MSP cases all used one trusted supplier as the route to its customers (**Confirmed** [11] [123] [52]; **Reported** [13] [47]).

Configuration is the breach. Capital One's firewall, First American's document URLs, Facebook's internal logs and app buckets, and Ecuador's open server were not exploits of a published CVE (**Confirmed** [91] [98] [101] [102] [108]). Regulators responded with penalties that turned on governance: the OCC on risk assessment before cloud migration, the SEC on disclosure controls, NY DFS on its cybersecurity regulation (**Confirmed** [94] [99] [100]).

Numbers need their definitions. IC3's $8.97 million in reported ransomware losses for 2019 excludes lost business and remediation, and IC3 itself calls it artificially low; Coveware's average payment is a payment, not a cost; Hydro's 800 MNOK is a total cost; Armis's 2 billion is an install base (**Confirmed** [59] [60] [35] [87]).

What is overstated and what is understated

- **Overstated: BlueKeep as a worm.** Microsoft called CVE-2019-0708 wormable on 14 May (**Confirmed** [61]); the first in-the-wild campaign, from 23 October, was operator-driven against exposed hosts and delivered a coin miner (**Confirmed** [64]). The feared worm did not appear in the 2019 record (**Inferred**).

- **Overstated: URGENT/11's 2 billion devices.** Armis's figure is an install base for VxWorks, not an affected count (**Confirmed** [87]), and CISA said no known public exploits targeted the flaws (**Confirmed** [86]); no in-the-wild use is recorded (Part 4).
- **Understated: ransomware's cost in the reported figures.** IC3's $8,965,847 in 2019 ransomware losses excludes lost business and remediation, and IC3 itself calls it artificially low (**Confirmed** [59]); Hydro's 800 MNOK is a single victim's total cost (**Confirmed** [35]).
- **Understated: patched edge devices.** In the Pulse cases CISA studied, victims that patched without resetting credentials stayed exposed, and CISA said a Citrix patch does not remediate a device already compromised (**Confirmed** [75] [71]). A patched VPN is not a clean VPN (**Inferred**).
- **Understated: business email compromise.** FBI reported $26,201,775,589 in exposed BEC losses from June 2016 to July 2019 (**Confirmed** [49]), and BEC was IC3's top loss type for 2019 at $1,776,549,688 (**Confirmed** [59]); that it outweighs ransomware in the FBI's own counts is **Inferred** from [49] [59].
- **Understated: configuration without a CVE.** Capital One's firewall, First American's document URLs, Facebook's logs and buckets and Ecuador's open server were not exploits of a published flaw (**Confirmed** [91] [98] [101] [102] [108]).

Sources

Every source below was opened on 3 November 2026. Grades apply to the source type: Confirmed for the publisher of the fact, Reported for secondary coverage, Demonstrated for public exploit code.

#	Source	URL	Opened	Grade
1	UK FCO and NCSC, UK condemns Russia's GRU over Georgia cyber-attacks (2020-02-20)	https://www.gov.uk/government/news/uk-condemns-russias-gru-over-georgia-cyber-attacks	2026-11-03	Confirmed
2	US Department of State, The United States Condemns Russian Cyber Attack Against the Country of Georgia (2020-02-20)	https://2017-2021.state.gov/the-united-states-condemns-russian-cyber-attack-against-the-country-of-georgia/	2026-11-03	Confirmed
3	Microsoft MSRC, Corporate IoT: a path to intrusion (2019-08-05)	https://www.microsoft.com/en-us/msrc/blog/2019/08/corporate-iot-a-path-to-intrusion	2026-11-03	Confirmed
4	ESET, Operation Ghost: The Dukes aren't back, they never left (2019-10-17)	https://www.welivesecurity.com/2019/10/17/operation-ghost-dukes-never-left/	2026-11-03	Confirmed
5	US Treasury, press release sm845, Treasury Sanctions Evil Corp (2019-12-05)	https://home.treasury.gov/news/press-releases/sm845	2026-11-03	Confirmed
6	Penguin Random House, *Sandworm* by Andy Greenberg (publication details)	https://www.penguinrandomhouse.com/books/597684/sandworm-by-andy-greenberg/	2026-11-03	Reported
7	UK NCSC with NSA, Turla group exploits Iranian APT to expand coverage of victims, advisory PDF (2019-10-21)	https://www.ncsc.gov.uk/files/Turla%20advisory%20UK%20FINAL.pdf	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
8	UK NCSC, news page for the Turla advisory (2019-10-21)	https://www.ncsc.gov.uk/news/turla-group-exploits-iran-apt-to-expand-coverage-of-victims	2026-11-03	Confirmed
9	Symantec (security.com), Waterbug: Espionage Group Rolls Out Brand-New Toolset in Attacks Against Governments (2019-06-20)	https://www.security.com/threat-intelligence/waterbug-espionage-governments	2026-11-03	Confirmed
10	FireEye (Google Cloud blog), APT41: A Dual Espionage and Cyber Crime Operation (2019-08-07)	https://cloud.google.com/blog/topics/threat-intelligence/apt41-dual-espionage-and-cyber-crime-operation	2026-11-03	Confirmed
11	Kaspersky Securelist, Operation ShadowHammer: a high-profile supply chain attack (2019-04-23)	https://securelist.com/operation-shadowhammer-a-high-profile-supply-chain-attack/90380/	2026-11-03	Confirmed
12	Kaspersky, press release on Operation ShadowHammer (2019-03-25)	https://www.kaspersky.com/about/press-releases/2019_operation-shadowhammer-new-supply-chain-attack	2026-11-03	Confirmed
13	Recorded Future and Rapid7, APT10 Targeted Norwegian MSP and US Companies in Sustained Campaign (2019-02-06)	recordedfuture.com, path /apt10-cyberespionage-campaign/ (not linked: the original returned 404 on 4 November 2026 and its Wayback Machine and archive.today captures returned 429; the claim was read from a third-party copy on 3 November 2026)	2026-11-03	Reported
14	Security Affairs, Operation Soft Cell (2019-06-25)	https://securityaffairs.com/87599/hacking/operation-soft-cell-telco-hack.html	2026-11-03	Reported
15	Microsoft Security Blog, GALLIUM: Targeting global telecom (2019-12-12)	https://www.microsoft.com/en-us/security/blog/2019/12/12/gallium-targeting-global-telecom/	2026-11-03	Confirmed
16	Fox-IT, Operation Wocao (2019-12-19)	https://www.fox-it.com/be/operation-wocao-shining-a-light-on-one-of-china-s-hidden-hacking-groups/	2026-11-03	Confirmed
17	Australian Prime Minister, statement to Parliament (2019-02-18), PM Transcripts	https://pmtranscripts.pmc.gov.au/node/37862	2026-11-03	Confirmed
18	CISA, CISA Statement on Iranian Cybersecurity Threats (2019-06-22)	https://www.cisa.gov/news-events/news/cisa-statement-iranian-cybersecurity-threats	2026-11-03	Confirmed
19	Symantec (security.com), Elfin: Relentless Espionage Group Targets Multiple Organizations in Saudi Arabia and U.S. (2019-03-27)	https://www.security.com/threat-intelligence/elfin-apt33-espionage	2026-11-03	Confirmed
20	Microsoft On the Issues, New steps to protect customers from hacking (2019-03-27)	https://blogs.microsoft.com/on-the-issues/2019/03/27/new-steps-to-protect-customers-from-hacking/	2026-11-03	Confirmed
21	Microsoft On the Issues, Recent cyberattacks require us all to be vigilant (2019-10-04)	https://blogs.microsoft.com/on-the-issues/2019/10/04/recent-cyberattacks-require-us-all-to-be-vigilant/	2026-11-03	Confirmed
22	The Register, on IBM X-Force's ZeroCleare report (2019-12-05)	https://www.theregister.com/2019/12/05/iran_zerocleare_attack/	2026-11-03	Reported

#	Source	URL	Opened	Grade
23	MITRE ATT&CK, Software S1151 ZeroCleare	https://attack.mitre.org/software/S1151/	2026-11-03	Confirmed
24	Kaspersky ICS CERT, summary of the Saudi NCA Dustman report	https://ics-cert.kaspersky.com/?p=255	2026-11-03	Reported
25	Cisco Talos, DNS Hijacking Abuses Trust in Core Internet Service (Sea Turtle) (2019-04-17)	https://blog.talosintelligence.com/seaturtle/	2026-11-03	Confirmed
26	CISA, AR19-100A, MAR-10135536-8, North Korean Trojan: HOPLIGHT (2019-04-10)	https://www.cisa.gov/news-events/analysis-reports/ar19-100a	2026-11-03	Confirmed
27	CISA, AR19-129A, MAR-10135536-21, North Korean Tunneling Tool: ELECTRICFISH (2019-05-09)	https://www.cisa.gov/news-events/analysis-reports/ar19-129a	2026-11-03	Confirmed
28	UN Security Council, Panel of Experts report S/2019/691 (2019-08-30)	https://documents.un.org/doc/undoc/gen/n19/243/04/pdf/n1924304.pdf	2026-11-03	Confirmed
29	US Treasury, press release sm774, sanctions on North Korean state-sponsored cyber groups (2019-09-13)	https://home.treasury.gov/news/press-releases/sm774	2026-11-03	Confirmed
30	FireEye (Google Cloud blog), TRITON Actor TTP Profile, Custom Attack Tools, Detections, and ATT&CK Mapping (2019-04-10)	https://cloud.google.com/blog/topics/threat-intelligence/triton-actor-ttp-profile-custom-attack-tools-detections	2026-11-03	Confirmed
31	MITRE ATT&CK, Campaign C0030 Triton Safety Instrumented System Attack	https://attack.mitre.org/campaigns/C0030/	2026-11-03	Confirmed
32	CrowdStrike, Big Game Hunting with Ryuk (2019-01-10)	https://www.crowdstrike.com/blog/big-game-hunting-with-ryuk-another-lucrative-targeted-ransomware/	2026-11-03	Confirmed
33	Norsk Hydro, Hydro subject to cyber attack (2019-03-19)	https://www.hydro.com/en/global/media/news/2019/hydro-subject-to-cyber-attack/	2026-11-03	Confirmed
34	Norsk Hydro, Update: Hydro subject to cyber attack (2019-03-19)	https://www.hydro.com/en/global/media/news/2019/update-hydro-subject-to-cyber-attack/	2026-11-03	Confirmed
35	Norsk Hydro, Cyber-attack on Hydro	https://www.hydro.com/en/global/media/on-the-agenda/cyber-attack/	2026-11-03	Confirmed
36	Insurance Journal, Reuters report on the Hydro attack (2019-03-20)	https://amp.insurancejournal.com/news/international/2019/03/20/521165.htm	2026-11-03	Reported
37	BleepingComputer, Police arrest criminals behind Norsk Hydro ransomware attack (2021-10)	https://www.bleepingcomputer.com/news/security/police-arrest-criminals-behind-norsk-hydro-ransomware-attack/	2026-11-03	Reported
38	Cisco Talos, Sodinokibi ransomware exploits WebLogic Server vulnerability (2019-04)	https://blog.talosintelligence.com/2019/04/sodinokibi-ransomware-exploits-weblogic.html	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
39	NIST NVD, CVE API 2.0 records for each CVE in Part 4 (example: CVE-2019-11510)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2019-11510	2026-11-03	Confirmed
40	TeamStarWolf library data and generated pages on main: data/attack/, data/weaknesses/ and mitre/	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-03	Confirmed
41	Cisco Talos, Emotet is back after a summer break (2019-09)	https://blog.talosintelligence.com/2019/09/emotet-is-back-after-summer-break.html	2026-11-03	Confirmed
42	Canadian Centre for Cyber Security, AL19-013, Ryuk ransomware targeting organizations globally (NCSC report)	https://www.cyber.gc.ca/en/alerts-advisories/ryuk-ransomware-targeting-organizations-globally-ncsc-report	2026-11-03	Confirmed
43	CISA, NCSC Releases Advisory on Ryuk Ransomware (2019-06-28)	https://www.cisa.gov/news-events/alerts/2019/06/28/ncsc-releases-advisory-ryuk-ransomware	2026-11-03	Confirmed
44	CISA, FBI and HHS, AA20-302A, Ransomware Activity Targeting the Healthcare and Public Health Sector	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-302a	2026-11-03	Confirmed
45	Toyota Boshoku, disclosure of fraudulent payment loss (2019-09-06)	https://www.toyota-boshoku.com/global/content/wp-content/uploads/190906e.pdf	2026-11-03	Confirmed
46	Texas Legislature, Texas DIR testimony handout on the August 2019 ransomware attack	`https://capitol.texas.gov/tlodocs/86R/handouts/C3852020080400001/7bd1e798-9055-4166-8ff4-89e12ff5964e.PDF`	2026-11-03	Confirmed
47	The Record, US arrests and charges Ukrainian man for Kaseya ransomware attack	https://therecord.media/us-arrests-and-charges-ukrainian-man-for-kaseya-ransomware-attack/	2026-11-03	Reported
48	US Treasury, press release jy0471, REvil designations (2021-11-08)	https://home.treasury.gov/news/press-releases/jy0471	2026-11-03	Confirmed
49	FBI IC3, PSA I-091019-PSA, Business Email Compromise: The $26 Billion Scam (2019-09-10)	https://www.ic3.gov/PSA/2019/PSA190910	2026-11-03	Confirmed
50	FBI, Operation reWired (2019-09-10)	`https://www.fbi.gov/news/stories/operation-rewired-bec-takedown-091019`	2026-11-03	Confirmed
51	DOJ Office of the Inspector General, audit of the FBI's FY2019 financial statements	https://oig.justice.gov/archives/reports/2019/a20017.pdf	2026-11-03	Confirmed
52	FBI IC3, PSA I-100219-PSA, High-Impact Ransomware Attacks Threaten U.S. Businesses and Organizations (2019-10-02)	https://www.ic3.gov/PSA/2019/PSA191002	2026-11-03	Confirmed
53	BleepingComputer, Allied Universal breached by Maze ransomware, stolen data leaked (2019-11)	https://www.bleepingcomputer.com/news/security/allied-universal-breached-by-maze-ransomware-stolen-data-leaked/	2026-11-03	Reported
54	SentinelLabs, Maze Ransomware Update: Extorting and Exposing Victims (update 2019-12-19)	https://www.sentinelone.com/labs/maze-ransomware-update-extorting-and-exposing-victims	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
55	FBI, Charges announced in malware conspiracy (2019-12-05)	https://www.fbi.gov/news/stories/charges-announced-in-malware-conspiracy-120519	2026-11-03	Confirmed
56	BleepingComputer, Sodinokibi ransomware hits Travelex, demands $3 million (2020-01)	https://www.bleepingcomputer.com/news/security/sodinokibi-ransomware-hits-travelex-demands-3-million/	2026-11-03	Reported
57	BleepingComputer, Travelex reportedly paid $2.3 million ransom (2020-04-09)	https://www.bleepingcomputer.com/news/security/travelex-reportedly-paid-23-million-ransom-to-restore-operations/	2026-11-03	Reported
58	CISA, AA20-010A, Continued Exploitation of Pulse Secure VPN Vulnerability (2020-01-10)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-010a	2026-11-03	Confirmed
59	FBI IC3, 2019 Internet Crime Report	https://www.ic3.gov/AnnualReport/Reports/2019_IC3Report.pdf	2026-11-03	Confirmed
60	Coveware, Ransomware Costs Double in Q4 as Ryuk, Sodinokibi Proliferate (2020-01)	https://coveware.com/2020/01/ransomware-costs-double-in-q4-as-ryuk-sodinokibi-proliferate/	2026-11-03	Confirmed
61	Microsoft MSRC, Prevent a worm by updating Remote Desktop Services (CVE-2019-0708) (2019-05-14)	https://www.microsoft.com/en-us/msrc/blog/2019/05/prevent-a-worm-by-updating-remote-desktop-services-cve-2019-0708	2026-11-03	Confirmed
62	CISA, AA19-168A, Microsoft Operating Systems BlueKeep Vulnerability (2019-06-17)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa19-168a	2026-11-03	Confirmed
63	Rapid7, Initial Metasploit Exploit Module for BlueKeep (CVE-2019-0708) (2019-09-06)	https://www.rapid7.com/blog/post/2019/09/06/initial-metasploit-exploit-module-for-bluekeep-cve-2019-0708/	2026-11-03	Demonstrated
64	Microsoft Security Blog, The new CVE-2019-0708 RDP exploit attacks explained (2019-11-07)	https://www.microsoft.com/en-us/security/blog/2019/11/07/the-new-cve-2019-0708-rdp-exploit-attacks-explained/	2026-11-03	Confirmed
65	Microsoft MSRC, Patch new wormable vulnerabilities in Remote Desktop Services (CVE-2019-1181/1182) (2019-08-13)	https://www.microsoft.com/en-us/msrc/blog/2019/08/patch-new-wormable-vulnerabilities-in-remote-desktop-services-cve-2019-1181-1182	2026-11-03	Confirmed
66	CISA, Known Exploited Vulnerabilities catalog, JSON feed (catalog version 2026.11.03)	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-03	Confirmed
67	CISA, AA20-275A, Potential for China Cyber Response to Heightened U.S.-China Tensions (2020-10-01)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-275a	2026-11-03	Confirmed
68	CISA, AA20-020A, Critical Vulnerability in Citrix Application Delivery Controller, Gateway, and SD-WAN WANOP	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-020a	2026-11-03	Confirmed
69	GitHub, projectzeroindia/CVE-2019-19781 (created 2020-01-10); trustedsec and cisagov repositories checked the same day	https://github.com/projectzeroindia/CVE-2019-19781	2026-11-03	Demonstrated

#	Source	URL	Opened	Grade
70	Mandiant (Google Cloud blog), 404 Exploit Not Found: Vigilante Deploying Mitigation for Citrix NetScaler Vulnerability While Maintaining Backdoor	https://cloud.google.com/blog/topics/threat-intelligence/vigilante-deploying-mitigation-for-citrix-netscaler-vulnerability-while-maintaining-backdoor/	2026-11-03	Confirmed
71	CISA, AA20-031A, Detecting Citrix CVE-2019-19781 (2020-01-31)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-031a	2026-11-03	Confirmed
72	CISA, AA20-258A, Chinese Ministry of State Security-Affiliated Cyber Threat Actor Activity (2020-09-14)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-258a	2026-11-03	Confirmed
73	CISA, ACSC, NCSC and FBI, AA21-209A, Top Routinely Exploited Vulnerabilities (2021-07-28)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-209a	2026-11-03	Confirmed
74	CERT/CC, VU#927237, Pulse Secure SSL VPN contains multiple vulnerabilities	https://www.kb.cert.org/vuls/id/927237/	2026-11-03	Confirmed
75	CISA, AA20-107A, Continued Threat Actor Exploitation Post Pulse Secure VPN Patching (2020-04-16)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-107a	2026-11-03	Confirmed
76	UK NCSC, Vulnerabilities exploited in VPN products used worldwide (2019-10-02, v2.0 2019-10-08)	https://www.ncsc.gov.uk/news/alert-vpn-vulnerabilities	2026-11-03	Confirmed
77	DEVCORE, Attacking SSL VPN, Part 2: Breaking the Fortigate SSL VPN (2019-08-09)	https://devco.re/blog/2019/08/09/attacking-ssl-vpn-part-2-breaking-the-Fortigate-ssl-vpn/	2026-11-03	Confirmed
78	Fortinet PSIRT, FG-IR-18-384 (CVE-2018-13379)	https://www.fortiguard.com/psirt/FG-IR-18-384	2026-11-03	Confirmed
79	Fortinet PSIRT blog, Update Regarding CVE-2018-13379 (2020-11)	https://www.fortinet.com/blog/psirt-blogs/update-regarding-cve-2018-13379	2026-11-03	Confirmed
80	Qualys, The Return of the WIZard: RCE in Exim (CVE-2019-10149) (2019-06-05)	https://www.qualys.com/2019/06/05/cve-2019-10149/return-wizard-rce-exim.txt	2026-11-03	Confirmed
81	Exim project, CVE-2019-10149 notice	https://www.exim.org/static/doc/security/CVE-2019-10149.txt	2026-11-03	Confirmed
82	CISA, NSA Releases Advisory on Sandworm Actors Exploiting Exim Vulnerability (2020-05-28)	https://www.cisa.gov/news-events/alerts/2020/05/28/nsa-releases-advisory-sandworm-actors-exploiting-exim-vulnerability	2026-11-03	Confirmed
83	Canadian Centre for Cyber Security, AL20-017, Continued exploitation of Exim vulnerability (2020-06-03)	https://www.cyber.gc.ca/en/alerts-advisories/continued-exploitation-exim-vulnerability	2026-11-03	Confirmed
84	Atlassian, Confluence Security Advisory 2019-03-20	https://confluence.atlassian.com/doc/confluence-security-advisory-2019-03-20-966660264.html	2026-11-03	Confirmed
85	Trend Micro, CVE-2019-3396 Redux: Confluence Vulnerability Exploited to Deliver Cryptocurrency Miner With Rootkit (2019-05-07)	https://www.trendmicro.com/en_us/research/19/e/cve-2019-3396-redux-confluence-vulnerability-exploited-to-deliver-cryptocurrency-miner-with-rootkit.html	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
86	CISA, ICSA-19-211-01, Wind River VxWorks (URGENT/11) (2019-07-30)	https://www.cisa.gov/news-events/ics-advisories/icsa-19-211-01	2026-11-03	Confirmed
87	Armis, URGENT/11	`https://www.armis.com/research/urgent-11/`	2026-11-03	Confirmed
88	CISA and FBI, AA20-133A, Top 10 Routinely Exploited Vulnerabilities (2020-05-12)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-133a	2026-11-03	Confirmed
89	Capital One, Capital One Announces Data Security Incident (2019-07-29)	https://www.capitalone.com/about/newsroom/capital-one-announces-data-security-incident/	2026-11-03	Confirmed
90	DOJ, W.D. Washington, Seattle tech worker arrested for data theft involving large financial services company (2019-07-29)	https://www.justice.gov/usao-wdwa/pr/seattle-tech-worker-arrested-data-theft-involving-large-financial-services-company	2026-11-03	Confirmed
91	US District Court, W.D. Washington, criminal complaint 2:19-mj-00344 (CourtListener RECAP copy)	https://storage.courtlistener.com/recap/gov.uscourts.wawd.276200/gov.uscourts.wawd.276200.1.0_4.pdf	2026-11-03	Confirmed
92	DOJ, W.D. Washington, Former Seattle tech worker indicted on federal charges for wire fraud and computer data theft (2019-08-28)	https://www.justice.gov/usao-wdwa/pr/former-seattle-tech-worker-indicted-federal-charges-wire-fraud-and-computer-data-theft	2026-11-03	Confirmed
93	DOJ, W.D. Washington, Former Seattle tech worker convicted of wire fraud and computer intrusions (2022-06-17)	https://www.justice.gov/usao-wdwa/pr/former-seattle-tech-worker-convicted-wire-fraud-and-computer-intrusions	2026-11-03	Confirmed
94	OCC, News Release 2020-101, OCC Assesses $80 Million Civil Money Penalty Against Capital One (2020-08-06)	https://www.occ.gov/news-issuances/news-releases/2020/nr-occ-2020-101.html	2026-11-03	Confirmed
95	KrebsOnSecurity, What We Can Learn from the Capital One Hack (2019-08-02)	https://krebsonsecurity.com/2019/08/what-we-can-learn-from-the-capital-one-hack/	2026-11-03	Reported
96	AWS Security Blog, Add defense in depth against open firewalls, reverse proxies, and SSRF vulnerabilities with enhancements to the EC2 Instance Metadata Service (2019-11-19)	https://aws.amazon.com/blogs/security/defense-in-depth-open-firewalls-reverse-proxies-ssrf-vulnerabilities-ec2-instance-metadata-service/	2026-11-03	Confirmed
97	KrebsOnSecurity, First American Financial Corp. Leaked Hundreds of Millions of Title Insurance Records (2019-05-24)	https://krebsonsecurity.com/2019/05/first-american-financial-corp-leaked-hundreds-of-millions-of-title-insurance-records/	2026-11-03	Reported
98	SEC, Administrative Proceeding order, First American Financial Corporation (2021-06-14)	`https://www.sec.gov/litigation/admin/2021/34-92176.pdf`	2026-11-03	Confirmed
99	SEC, Press Release 2021-102 (2021-06-15)	`https://www.sec.gov/news/press-release/2021-102`	2026-11-03	Confirmed
100	NY Department of Financial Services, press release on charges against First American Title (2020-07-22)	https://www.dfs.ny.gov/reports_and_publications/press_releases/pr202007221	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
101	Facebook, Keeping Passwords Secure (2019-03-21, updated 2019-04-18)	https://about.fb.com/news/2019/03/keeping-passwords-secure/	2026-11-03	Confirmed
102	UpGuard, Losing Face: Two More Cases of Third-Party Facebook App Data Exposure	https://www.upguard.com/breaches/facebook-user-data-leak	2026-11-03	Confirmed
103	FTC, FTC Imposes $5 Billion Penalty and Sweeping New Privacy Restrictions on Facebook (2019-07-24)	`https://www.ftc.gov/news-events/news/press-releases/2019/07/ftc-imposes-5-billion-penalty-sweeping-new-privacy-restrictions-facebook`	2026-11-03	Confirmed
104	TechCrunch, report on exposed Facebook phone numbers (2019-09-04)	https://techcrunch.com/2019/09/04/facebook-phone-numbers-exposed/	2026-11-03	Reported
105	Facebook, An Update on Our Plans to Restrict Data Access on Facebook (2018-04-04)	https://about.fb.com/news/2018/04/restricting-data-access/	2026-11-03	Confirmed
106	Meta, The Facts on News Reports About Facebook Data (2021-04-06)	https://about.fb.com/news/2021/04/facts-on-news-reports-about-facebook-data/	2026-11-03	Confirmed
107	Irish Data Protection Commission, decision in Facebook data scraping inquiry (2022-11-28)	https://www.dataprotection.ie/en/news-media/press-releases/data-protection-commission-announces-decision-in-facebook-data-scraping-inquiry	2026-11-03	Confirmed
108	vpnMentor, report on the Ecuador data leak (2019-09-16)	https://www.vpnmentor.com/blog/report-ecuador-leak/	2026-11-03	Confirmed
109	Primicias, Fiscalía actions against Novaestrat (2019-09-17)	https://primicias.ec/noticias/tecnologia/directivos-novaestrat-filtracion-datos-fiscalia	2026-11-03	Reported
110	The Register, Novaestrat executive arrested (2019-09-18)	https://www.theregister.com/2019/09/18/novaestrat_exec_arrested_ecuador_data_leak/	2026-11-03	Reported
111	Wolf Theiss, Bulgaria fines in millions for personal data breaches	https://www.wolftheiss.com/insights/bulgaria-fines-in-millions-for-personal-data-breaches/	2026-11-03	Reported
112	MITRE ATT&CK, Versions	https://attack.mitre.org/resources/versions/	2026-11-03	Confirmed
113	MITRE ATT&CK, Updates, October 2019	https://attack.mitre.org/resources/updates/updates-october-2019/	2026-11-03	Confirmed
114	MITRE ATT&CK, Updates, July 2020	https://attack.mitre.org/resources/updates/updates-july-2020/	2026-11-03	Confirmed
115	TeamStarWolf library, data/attack/superseded_by.jsonl	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/superseded_by.jsonl	2026-11-03	Confirmed
116	CrowdStrike, 2020 Global Threat Report (2019 data)	https://go.crowdstrike.com/rs/281-OBQ-266/images/Report2020CrowdStrikeGlobalThreatReport.pdf	2026-11-03	Confirmed
117	Verizon, 2020 Data Breach Investigations Report (data 2018-11-01 to 2019-10-31)	https://www.verizon.com/business/resources/reports/2020-data-breach-investigations-report.pdf	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
118	CISA, Emergency Directive 19-01, Mitigate DNS Infrastructure Tampering (2019-01-22, closed)	https://www.cisa.gov/news-events/directives/ed-19-01-mitigate-dns-infrastructure-tampering-closed	2026-11-03	Confirmed
119	MITRE ATT&CK, Group G0034 Sandworm Team	https://attack.mitre.org/groups/G0034/	2026-11-03	Confirmed
120	Capital One, Information on the Capital One cyber incident	https://www.capitalone.com/digital/facts2019/	2026-11-03	Confirmed
121	MITRE ATT&CK, Technique T1552.005 Cloud Instance Metadata API	https://attack.mitre.org/techniques/T1552/005/	2026-11-03	Confirmed
122	Microsoft Security Blog, Human-operated ransomware attacks: A preventable disaster (2020-03-05)	https://www.microsoft.com/en-us/security/blog/2020/03/05/human-operated-ransomware-attacks-a-preventable-disaster/	2026-11-03	Confirmed
123	SolarWinds, New Findings From Our Investigation of SUNBURST (2021-01-11)	https://www.solarwinds.com/blog/new-findings-from-our-investigation-of-sunburst	2026-11-03	Confirmed
124	MITRE ATT&CK, live object pages: S0372 LockerGoga (also S0400, S0449, S0443, S1151, S0562, G0102, G1041, C0001, C0014, C0024)	https://attack.mitre.org/software/S0372/	2026-11-03	Confirmed
125	TeamStarWolf library, NOTABLE_INCIDENTS.md	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/NOTABLE_INCIDENTS.md	2026-11-03	Confirmed
126	TeamStarWolf library, scripts/validate_navigator.py (layer format)	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/scripts/validate_navigator.py	2026-11-03	Confirmed
127	TeamStarWolf library, mitre/capec/CAPEC-126.md	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/mitre/capec/CAPEC-126.md	2026-11-03	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Threat Actors
- Malware Families
- Notable Incidents
- CVE Reference

- Ransomware Defense Reference, Cloud Attack Reference
- CWE Reference, CAPEC Reference, D3FEND Reference
- Cybersecurity Book List
- Case studies: APT41: The Public Record, SolarWinds, The Year 2020 in Intrusions
- Generated MITRE pages: groups Sandworm Team G0034, APT28 G0007, APT29 G0016, Turla G0010, OilRig G0049, APT33 G0064, Magic Hound G0059, Sea Turtle G1041, Lazarus Group G0032, Wizard Spider G0102, Indrik Spider G0119 and GOLD SOUTHFIELD G0115; campaigns Operation Ghost C0023, Operation Wocao C0014 and SolarWinds Compromise C0024; software Ryuk S0446, REvil S0496, Maze S0449, LockerGoga S0372, Emotet S0367, TrickBot S0266 and ShadowPad S0596; techniques Exploit Public-Facing Application T1190, External Remote Services T1133, Data Encrypted for Impact T1486, Compromise Software Supply Chain T1195.002 and Cloud Instance Metadata API T1552.005